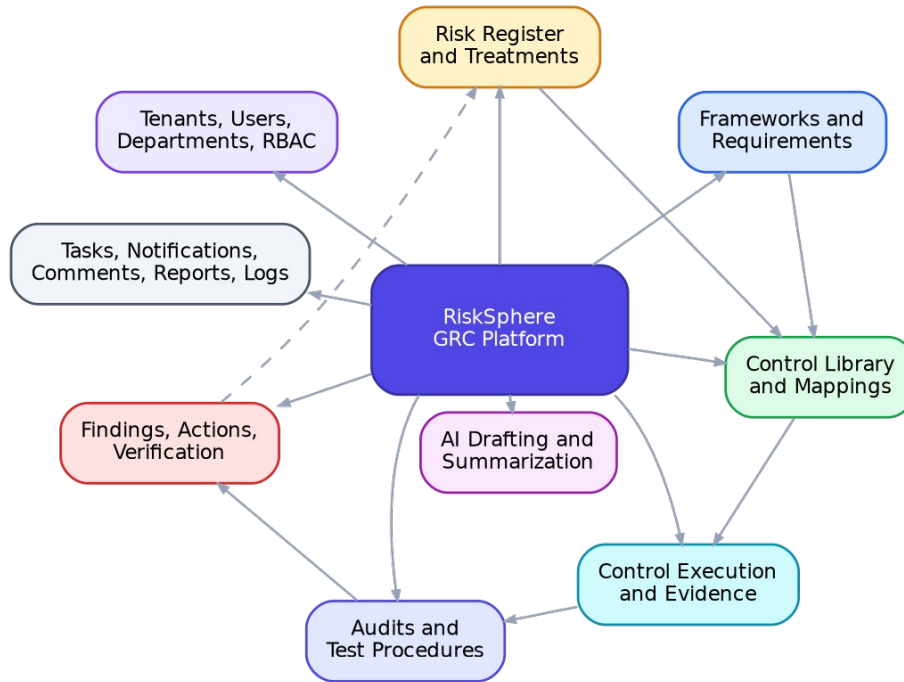


RISKSPHERE

Multi-Tenant Governance, Risk, Compliance and Audit Management Platform

Complete Product Requirements Document and Technical Delivery Blueprint



RiskSphere domain module map

Document	Value
Product name	RiskSphere
Document type	Product Requirements Document (PRD) with implementation blueprint
Version	1.0
Status	Baseline for design and development
Prepared for / date	Multi-tenant full-stack training project 6 August 2026 (Asia/Karachi)
Implementation scope	Frontend, backend and database; infrastructure deployment is outside the initial scope

Core lifecycle: Risk or compliance requirement -> control -> recurring execution -> evidence -> audit test -> finding -> corrective action -> independent verification -> closure.

Document Control

Field	Definition
Owner	Project development team
Primary audience	Product owner, frontend developer, backend developer, database designer, QA reviewer and project supervisors
Purpose	Define the complete product scope, business workflows, technical stack, data boundaries, implementation phases and acceptance conditions.
Change policy	Material changes to tenancy, authorization, workflow states or core entities must be recorded as explicit architecture decisions.
Assumptions	The application is a training-grade but production-inspired modular monolith, not a regulated certification product or legal compliance opinion.
Out of scope	Cloud hosting, Kubernetes, Docker orchestration, AWS infrastructure, billing, enterprise SSO and production operations.

Version History

Version	Date	Summary
1.0	6 Aug 2026	Initial complete PRD based on agreed scope, stack and feature set.

How to Use This Document

This PRD is intentionally detailed. Product sections explain what RiskSphere must accomplish; implementation sections explain how the agreed stack should support those outcomes without turning the system into premature microservices. Requirements marked **MUST** define the baseline. **SHOULD** requirements are recommended for the first complete version if schedule permits. **MAY** requirements are deferred or optional.

Table of Contents

Table of contents updates when opened in Microsoft Word.

Major sections: Executive Summary; Product Definition; Personas and Authorization; Functional Scope; Workflow Specifications; User Experience; Technical Architecture; Data Design; API Design; Notifications and Email; AI Assistant; Security; Non-Functional Requirements; Testing; Roadmap; Acceptance Criteria; Demo Scenario; Appendices.

1. Executive Summary

RiskSphere is a multi-tenant web platform for organizations to identify and assess risks, map compliance requirements to reusable controls, schedule recurring control work, collect and review evidence, perform audits, issue findings, track corrective actions and require independent verification before closure. It replaces fragmented spreadsheets, email threads and disconnected task lists with a traceable system of record.

The product is designed as a modular monolith in a monorepo. Next.js provides the web interface, NestJS owns business logic and REST APIs, PostgreSQL stores relational data, and Prisma provides the typed persistence layer. The tenancy model is a shared database and shared schema, with organizationId on every tenant-owned record and tenant context enforced centrally in the backend.

The system is intentionally more advanced than a CRUD project. Its core educational value comes from tenant isolation, tenant-scoped RBAC, many-to-many mappings, recurring work, evidence versioning, approvals, immutable audit logs, dashboards, notifications and multi-step state transitions.

1.1 Product Vision

Vision: Give each organization one secure, structured and auditable workspace for managing governance, risk, compliance and internal audit work from identification through verified closure.

1.2 Success Definition

- A tenant administrator can onboard an organization, invite users, create departments and assign tenant-scoped roles without accessing another tenant.
- A GRC manager can register a risk, map controls and requirements, schedule control work and monitor status from dashboards.
- A control owner can perform an assigned execution, submit evidence and respond to reviewer rejection.
- An auditor can plan an audit, execute tests, record exceptions and create findings linked to controls, risks and requirements.
- A finding owner can execute remediation, but cannot independently close their own finding.
- A reviewer can verify remediation and either close or reopen the finding with a complete history.
- Every sensitive action is permission checked, tenant scoped and recorded in an audit log.

1.3 Product Boundaries

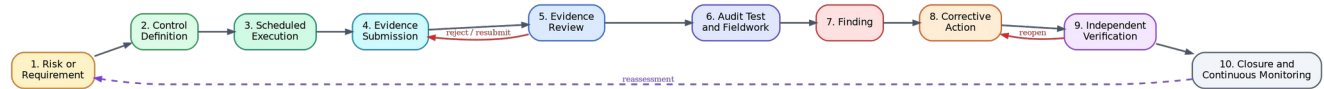
Included in baseline	Explicitly deferred
Tenant onboarding, users, departments and tenant-scoped RBAC	Billing and subscription management
Risk, compliance, controls, executions, evidence, audits, findings and remediation	Vendor risk, policy management, incident management and business continuity
Basic in-app and transactional email notifications	Real-time chat, push notifications and complex workflow designer
Basic AI drafting and summarization assistance	Tenant-wide RAG chatbot over documents and autonomous decision making
CSV exports and printable views	Custom report builder and full BI platform
Development file storage abstraction	Cloud storage deployment and production CDN configuration

2. Product Context and Problem Definition

2.1 Problem Statement

Organizations frequently manage risk registers, compliance requirements, control evidence, audits and remediation in separate spreadsheets, shared folders, ticketing systems and email. This fragmentation makes ownership unclear, deadlines easy to miss, evidence difficult to review, and closure difficult to verify. It also produces weak traceability between a business risk, the control intended to reduce it, the proof that the control operated, the audit result and the final remediation outcome.

2.2 Core Business Lifecycle



End-to-end GRC and audit lifecycle

The lifecycle is cyclical rather than linear. Closed findings and completed audits feed back into risk reassessment, control redesign and future audit planning.

2.3 Product Principles

Principle	Meaning
Tenant isolation by default	Every request and data access path starts from authenticated tenant context.
Human accountability	AI may draft or summarize, but humans approve, issue, verify and close records.
Traceability over convenience	Important state changes are historical events, not silently overwritten fields.
Reusable controls	One control may mitigate multiple risks and satisfy multiple requirements.
Independent closure	The owner performing remediation cannot be the sole verifier of effectiveness.
Modular monolith first	Clear modules and interfaces without premature distributed systems.
Configurable but bounded	Tenants may configure useful scales and categories, but not arbitrary workflow programming in v1.

2.4 Example Value for TripVlog

TripVlog could register unreliable HLS delivery as a technology risk, define controls for media conversion, signed URL validity and cross-platform playback testing, require recurring monitoring evidence, test those controls in an internal audit, issue a finding when feed records return inconsistent stream URLs, assign corrective actions to Backend and DevOps, and require an independent auditor to verify the fix before closure.

3. Goals, Non-Goals and Product Metrics

3.1 Goals

- Build a credible multi-tenant SaaS-style application that demonstrates frontend, backend and relational database integration.
- Support the complete GRC-to-audit lifecycle with assignment, evidence, review and closure workflows.
- Provide strong tenant isolation and tenant-scoped authorization as first-class architectural concerns.
- Give users actionable dashboards and a unified view of their assigned work.
- Maintain a complete audit history for important business and security events.
- Keep the design extensible for future modules without implementing unnecessary infrastructure now.

3.2 Non-Goals

- RiskSphere will not certify that a customer is legally or regulatorily compliant.
- RiskSphere will not automatically approve controls, evidence, findings or remediation.
- RiskSphere will not implement a separate database or schema for each tenant in v1.
- RiskSphere will not use microservices, Kafka, Kubernetes, Redis or WebSockets in the initial baseline.
- RiskSphere will not provide a production-grade file scanning or malware detection service in the training scope.
- RiskSphere will not reproduce copyrighted compliance framework text without appropriate licensing.

3.3 Suggested Product Metrics

Metric	Definition	Initial target
Tenant isolation defects	Confirmed cross-tenant access paths	0
Assigned task visibility	Assigned work appearing in My Tasks	100% of supported workflow tasks
Audit trace coverage	Material actions that produce an audit event	>=95% of listed sensitive actions
Workflow completion	Core demo scenario reaches verified closure	End-to-end without database manipulation
API documentation coverage	Implemented REST endpoints represented in Swagger	100% of public endpoints
Automated test coverage	Critical service and authorization paths covered	Prioritize critical paths; suggested >=70% line coverage
Notification delivery	Expected basic in-app notifications created	>=99% in test suite

4. Users, Personas and Organization Model

4.1 Tenant and Membership Model

A user account is global, while access is granted through organization memberships. The same person may belong to multiple organizations and hold a different role in each. The active organization context determines permissions, visible data and navigation.

Persona	Primary responsibilities
Platform Administrator	Create, suspend and monitor tenants; manage platform-level configuration without participating in normal tenant workflows.
Organization Administrator	Manage tenant settings, users, invitations, departments, roles and configuration.
GRC Manager	Oversee risk, compliance, controls, evidence health, dashboards and reporting.
Risk Manager	Maintain risk methodology, facilitate assessments and monitor treatment.
Risk Owner	Own assigned risks, treatments, reviews and residual risk decisions.
Compliance Manager	Manage frameworks, requirements, applicability and compliance assessments.
Control Owner	Own control definitions and ensure recurring control execution.
Evidence Contributor	Perform control work and submit required evidence.
Evidence Reviewer	Review, approve, reject and request resubmission of evidence.
Audit Lead	Plan audits, assign auditors, review work and approve findings.
Internal Auditor	Execute test procedures, document exceptions and draft findings.
Finding / Action Owner	Respond to findings and deliver corrective actions.
Independent Verifier	Assess remediation evidence and close or reopen findings.
Viewer	Read authorized records and reports without modification rights.

4.2 Role and Permission Design

Roles are collections of permissions. Business logic should check permission keys rather than hard-coding role names. System roles may be seeded, while tenant-defined custom roles are optional for the first version. Permissions are evaluated against the active organization membership.

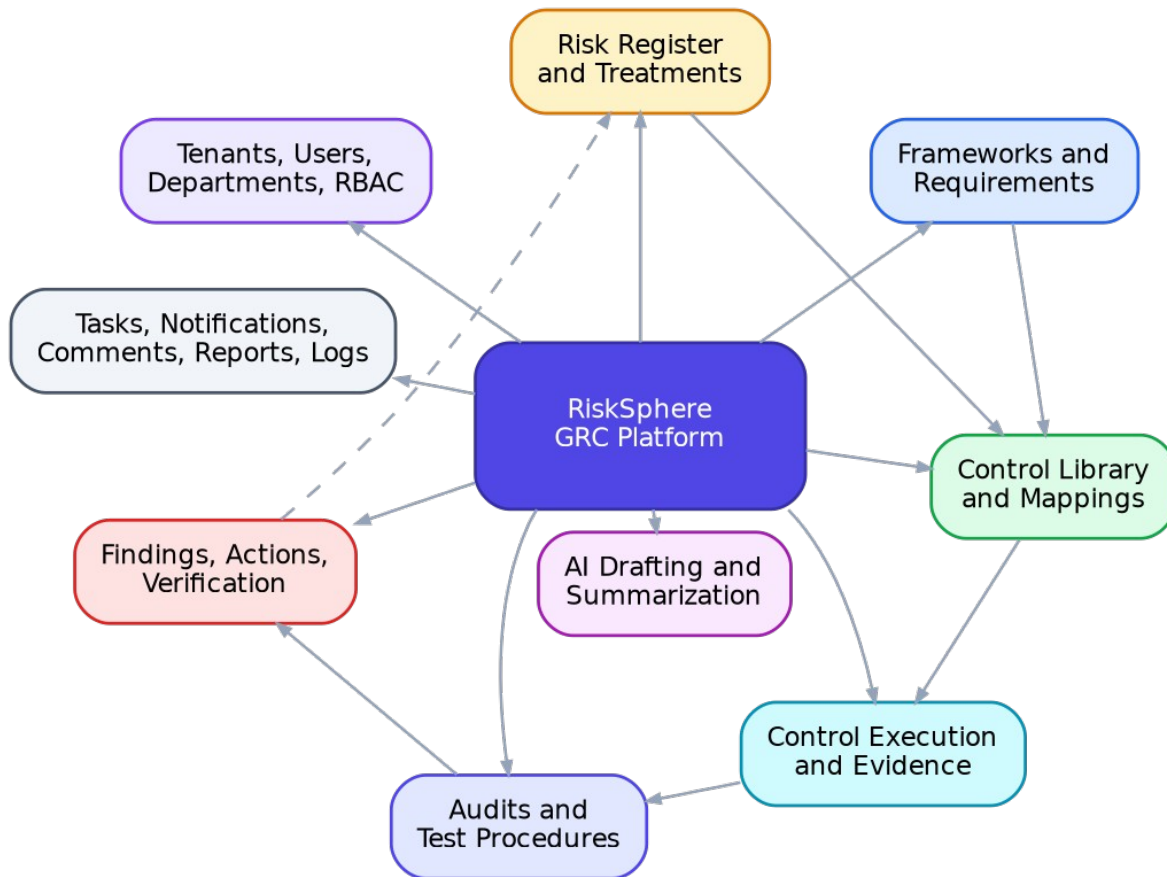
Permission	Meaning
organization.manage	Update organization profile and settings
member.invite	Invite users
member.manage	Activate, deactivate and assign memberships
department.manage	Create and update departments
role.manage	Manage tenant roles and permission assignments
risk.read	View risks
risk.create	Create risks

Permission	Meaning
risk.update	Update risks
risk.approve	Approve risks
risk.assign	Assign owners
framework.manage	Manage frameworks
requirement.manage	Manage requirements and applicability
control.manage	Create and update controls
control.map	Map controls to risks and requirements
control.execute	Perform control executions
evidence.submit	Submit evidence
evidence.review	Approve or reject evidence
audit.manage	Plan and manage audits
audit.test	Execute assigned audit tests
audit.review	Review audit work
finding.create	Draft findings
finding.issue	Issue findings
finding.respond	Respond to findings
finding.close	Close verified findings
action.manage	Create and update corrective actions
verification.perform	Perform independent verification
report.read	View reports
report.export	Export tenant data
audit_log.read	View audit logs
ai.use	Use AI drafting and summarization tools

4.3 Authorization Rules

- A valid JWT alone is insufficient; the user must also have an active membership in the selected organization.
- The backend must derive organizationId from server-validated context, not trust it from a request body.
- Resource ownership may further limit access even when a broad permission exists, such as an auditor viewing assigned tests only.
- Platform administrator access and tenant access are separate modes and must be clearly logged.
- Independent verification must reject cases where verifier and corrective-action owner are the same user unless an explicit authorized exception is recorded.

5. Functional Scope Overview



Functional modules and relationships

ID	Feature	Single-sentence purpose
F01	Tenant and Organization Management	Creates and manages isolated organizations, profiles, status and settings.
F02	Authentication and Account Management	Handles invitations, login, JWT sessions, verification and password recovery.
F03	Roles and Permissions	Controls tenant-specific access to features and records.
F04	Dashboard	Displays organization metrics, personal assignments and deadlines.
F05	Risk Management	Records, scores, assigns, treats, reviews and monitors risks.
F06	Compliance Frameworks and Requirements	Manages frameworks, requirements, applicability, ownership and assessment.
F07	Control Library	Defines reusable controls that mitigate risks and satisfy requirements.
F08	Control Mappings	Links controls to risks and requirements with coverage justification.

ID	Feature	Single-sentence purpose
F09	Recurring Control Execution	Generates scheduled control tasks and tracks their completion.
F10	Evidence Management	Collects, versions, reviews, approves and rejects proof of control operation.
F11	Audit Planning	Defines audit objectives, scope, team, schedule and status.
F12	Audit Programs and Procedures	Breaks audits into assigned test procedures and working-paper requirements.
F13	Audit Testing and Fieldwork	Records samples, exceptions, conclusions and review decisions.
F14	Audit Findings	Documents deficiencies, impact, root cause, severity and responsibility.
F15	Corrective Actions	Tracks remediation plans, milestones, evidence and due dates.
F16	Independent Verification and Closure	Confirms remediation effectiveness before closure or reopening.
F17	Tasks and Assignments	Aggregates assigned work into a unified personal queue.
F18	Notifications and Escalations	Alerts users to assignments, decisions and approaching or missed deadlines.
F19	Comments and Collaboration	Adds record-specific discussion, mentions and attachments.
F20	Audit Trail and Activity History	Records immutable security and business events.
F21	Reports and Analytics	Provides operational dashboards, metrics, printable views and CSV export.
F22	Search, Filtering and Saved Views	Helps users locate and organize large record sets.
F23	Tenant Configuration	Configures risk scales, categories, frequencies, severities and reminders.
F24	Platform Administration	Manages tenants and platform-level status without normal tenant participation.
F25	AI Assistance	Provides human-reviewed drafting, suggestions and summarization through Groq-hosted inference.

6. Detailed Functional Requirements

Each feature below defines its purpose, actors, baseline requirements, business rules, workflow and acceptance conditions. IDs are stable references for design, implementation and QA.

F01 - Tenant and Organization Management

Establish the tenant boundary and give each organization an isolated profile, membership space and configuration context.

Dimension	Definition
Primary actors	Platform Administrator, Organization Administrator
Status workflow	Provisioned -> Active -> Suspended -> Archived

Functional requirements

- F01-FR-01 - Create a tenant with unique name and slug.
- F01-FR-02 - Update organization profile, logo reference, timezone, locale and status.
- F01-FR-03 - Create and maintain departments and optional parent-child hierarchy.
- F01-FR-04 - Suspend or archive a tenant without deleting audit history.
- F01-FR-05 - Switch active organization when a user has multiple memberships.
- F01-FR-06 - Prevent all cross-tenant list, detail, mutation, export and search access.

Business rules

- F01-BR-01 - Tenant slug must be globally unique.
- F01-BR-02 - Suspension blocks tenant access but preserves records.
- F01-BR-03 - Tenant deletion is not exposed in v1; archive or suspend instead.

Acceptance conditions

- F01-AC-01 - Two tenants can create records with identical business codes without collision.
- F01-AC-02 - A user from Tenant A cannot access a guessed Tenant B resource ID.
- F01-AC-03 - Suspending a tenant blocks normal user access and creates a platform audit event.

F02 - Authentication and Account Management

Secure user identity and session lifecycle while delivering invitation, verification and recovery emails through SendGrid.

Dimension	Definition
Primary actors	Invited User, All authenticated users, Organization Administrator
Status workflow	Invited -> Pending Verification -> Active -> Locked/Deactivated

Functional requirements

- F02-FR-01 - Invite a user by email into a specific organization.
- F02-FR-02 - Accept invitation and create or link a global account.
- F02-FR-03 - Verify email ownership.
- F02-FR-04 - Log in with email and password.
- F02-FR-05 - Issue short-lived access and longer-lived refresh tokens.
- F02-FR-06 - Rotate refresh tokens and revoke reused or expired tokens.
- F02-FR-07 - Log out the current session and optionally all sessions.
- F02-FR-08 - Request and complete password reset using one-time expiring tokens.
- F02-FR-09 - Change password after re-authentication.
- F02-FR-10 - Deactivate an account or membership without hard deletion.

Business rules

- F02-BR-01 - Passwords must be hashed with a modern adaptive algorithm.
- F02-BR-02 - Reset and invitation tokens are single use and stored as hashes.
- F02-BR-03 - Authentication responses must not reveal whether an unknown email exists.
- F02-BR-04 - SendGrid is an email transport, not the authentication system.

Acceptance conditions

- F02-AC-01 - Expired invitations and reset tokens are rejected.
- F02-AC-02 - Refresh token rotation invalidates the previous token.
- F02-AC-03 - Email links route to the correct Next.js page and complete through NestJS APIs.

F03 - Tenant-Scoped RBAC

Authorize actions according to permissions assigned through the user membership in the active organization.

Dimension	Definition
Primary actors	Organization Administrator, All tenant users
Status workflow	Role Active -> Updated -> Archived

Functional requirements

- F03-FR-01 - Seed standard roles and permissions.
- F03-FR-02 - Assign one or more roles to a membership.
- F03-FR-03 - Optionally create tenant-specific custom roles.
- F03-FR-04 - Display navigation according to effective permissions.
- F03-FR-05 - Enforce permissions again in backend guards and services.
- F03-FR-06 - Support resource-level constraints such as assigned auditor or owner.

Business rules

- F03-BR-01 - Frontend hiding is convenience only and never a security boundary.
- F03-BR-02 - Permission checks must use the active membership.
- F03-BR-03 - Changes to roles and permissions are audit logged.

Acceptance conditions

- F03-AC-01 - Removing a permission takes effect on the next authorized request.
- F03-AC-02 - A user with the same global account may have different effective permissions in two organizations.
- F03-AC-03 - Unauthorized endpoint calls return a consistent 403 response.

F04 - Role-Based Dashboard

Give each user a prioritized overview of organization health and personal responsibilities.

Dimension	Definition
Primary actors	All authenticated tenant users
Status workflow	Not applicable

Functional requirements

- F04-FR-01 - Show risk counts by level and status.
- F04-FR-02 - Show compliance and control coverage summaries.
- F04-FR-03 - Show active audits and open findings.
- F04-FR-04 - Show overdue actions and upcoming control executions.
- F04-FR-05 - Show evidence awaiting review.
- F04-FR-06 - Show My Tasks and recent notifications.

- F04-FR-07 - Filter dashboard data by permitted department where applicable.

Business rules

- F04-BR-01 - Dashboard numbers must derive from tenant-scoped queries.
- F04-BR-02 - Metric definitions must be documented and consistent with detail lists.
- F04-BR-03 - Empty states must explain how data is created.

Acceptance conditions

- F04-AC-01 - Clicking a dashboard metric opens a pre-filtered list.
- F04-AC-02 - Counts match the corresponding filtered list.
- F04-AC-03 - Users do not see metrics for records they are not authorized to access.

F05 - Risk Management

Maintain the organization risk register from identification through treatment, monitoring and closure.

Dimension	Definition
Primary actors	GRC Manager, Risk Manager, Risk Owner, Viewer
Status workflow	Draft -> Under Review -> Approved -> Treatment in Progress -> Monitored -> Closed

Functional requirements

- F05-FR-01 - Create risk categories and risks.
- F05-FR-02 - Assign department and owner.
- F05-FR-03 - Capture likelihood and impact for inherent risk.
- F05-FR-04 - Calculate score and level from tenant configuration.
- F05-FR-05 - Record existing controls and residual assessment.
- F05-FR-06 - Select treatment: accept, avoid, mitigate or transfer.
- F05-FR-07 - Create treatment plan, due date and review date.
- F05-FR-08 - Submit for review and approval.
- F05-FR-09 - Reassess risk while preserving assessment history.
- F05-FR-10 - Display risk heat map and risk timeline.

Business rules

- F05-BR-01 - Score is calculated server-side using the active tenant matrix.
- F05-BR-02 - Approval and risk acceptance require explicit permissions.
- F05-BR-03 - Closed risks remain searchable and retain mappings and history.

Acceptance conditions

- F05-AC-01 - Changing likelihood or impact creates a new assessment history entry.
- F05-AC-02 - Risk score and level match configured matrix boundaries.
- F05-AC-03 - A risk can be linked to multiple controls and vice versa.

F06 - Compliance Frameworks and Requirements

Represent internal or external standards and track the applicability and compliance status of their requirements.

Dimension	Definition
Primary actors	Compliance Manager, GRC Manager, Requirement Owner
Status workflow	Draft -> Active -> Superseded -> Archived

Functional requirements

- F06-FR-01 - Create framework name, version, source and description.
- F06-FR-02 - Create hierarchical requirements with codes and parent relationships.
- F06-FR-03 - Assign owners and departments.
- F06-FR-04 - Mark applicable, not applicable or undecided with justification.
- F06-FR-05 - Assess compliance status and notes.
- F06-FR-06 - Archive superseded versions while preserving evidence and mappings.
- F06-FR-07 - Import sample framework data through controlled seed or CSV process.

Business rules

- F06-BR-01 - Requirement codes are unique within a framework and tenant.
- F06-BR-02 - Not Applicable requires a justification.
- F06-BR-03 - Framework content must respect licensing and copyright constraints.

Acceptance conditions

- F06-AC-01 - Requirement hierarchy renders correctly.
- F06-AC-02 - Compliance status changes are historical events.
- F06-AC-03 - Requirements without controls can be identified in reports.

F07 - Control Library

Define reusable controls with clear ownership, frequency, evidence expectations and lifecycle status.

Dimension	Definition
Primary actors	GRC Manager, Control Owner, Compliance Manager
Status workflow	Draft -> Under Review -> Active -> Retired

Functional requirements

- F07-FR-01 - Create control code, objective, procedure and description.
- F07-FR-02 - Classify preventive, detective or corrective.
- F07-FR-03 - Classify manual, automated or hybrid.
- F07-FR-04 - Assign owner, reviewer and department.
- F07-FR-05 - Configure frequency, effective date and next review date.
- F07-FR-06 - Define evidence instructions and expected evidence types.
- F07-FR-07 - Activate, retire or replace controls.
- F07-FR-08 - Track design and operating effectiveness separately.

Business rules

- F07-BR-01 - Control codes are unique per tenant.
- F07-BR-02 - Retiring a control does not delete historical executions or mappings.
- F07-BR-03 - Only active controls generate new scheduled executions.

Acceptance conditions

- F07-AC-01 - A control can satisfy multiple requirements and mitigate multiple risks.
- F07-AC-02 - Control changes are visible in activity history.
- F07-AC-03 - Activation validates owner, frequency and evidence instructions.

F08 - Risk and Requirement Control Mapping

Create explicit, reviewable relationships showing what each control mitigates or satisfies.

Dimension	Definition
Primary actors	GRC Manager, Risk Manager, Compliance Manager

Dimension	Definition
Status workflow	Proposed -> Confirmed -> Inactive

Functional requirements

- F08-FR-01 - Map a risk to one or more controls.
- F08-FR-02 - Map a requirement to one or more controls.
- F08-FR-03 - Record coverage type, justification and mapping owner.
- F08-FR-04 - Show unmapped risks and requirements.
- F08-FR-05 - Show shared controls across frameworks.
- F08-FR-06 - Disable a mapping while preserving history.

Business rules

- F08-BR-01 - Mapping uniqueness must include tenant and both related IDs.
- F08-BR-02 - Both linked resources must belong to the same tenant.
- F08-BR-03 - Deleting a record must not silently erase mapping history; archive where appropriate.

Acceptance conditions

- F08-AC-01 - Cross-tenant IDs are rejected even when syntactically valid.
- F08-AC-02 - Coverage reports resolve many-to-many relationships correctly.
- F08-AC-03 - Inactive mappings are excluded from current coverage but retained historically.

F09 - Recurring Control Execution

Turn an active control schedule into trackable work for a performer and reviewer.

Dimension	Definition
Primary actors	Control Owner, Evidence Contributor, Evidence Reviewer
Status workflow	Scheduled -> In Progress -> Evidence Submitted -> Under Review -> Approved; or Rejected -> Resubmitted; overdue is derived/flagged

Functional requirements

- F09-FR-01 - Create execution instances from frequency and schedule.
- F09-FR-02 - Assign performer and reviewer.
- F09-FR-03 - Provide period, due date, instructions and status.
- F09-FR-04 - Start, pause and complete work.
- F09-FR-05 - Mark overdue based on due date and grace period.
- F09-FR-06 - Allow controlled manual generation for testing or exceptions.
- F09-FR-07 - Maintain links to control version and evidence submissions.
- F09-FR-08 - Prevent duplicate generation for the same period.

Business rules

- F09-BR-01 - Control definition and execution are separate entities.
- F09-BR-02 - Execution status is derived from valid workflow transitions.
- F09-BR-03 - Schedule generation must be idempotent.

Acceptance conditions

- F09-AC-01 - Running the scheduler twice does not duplicate executions.
- F09-AC-02 - Only assigned users or authorized managers can update execution work.
- F09-AC-03 - Approved executions retain the evidence and review used for approval.

F10 - Evidence Management

Collect and review proof that a control was operated for a defined execution period.

Dimension	Definition
Primary actors	Evidence Contributor, Evidence Reviewer, Auditor
Status workflow	Draft -> Submitted -> Under Review -> Approved; or Rejected -> Resubmitted

Functional requirements

- F10-FR-01 - Create draft evidence submission.
- F10-FR-02 - Attach one or more files, URLs or text items.
- F10-FR-03 - Record title, description, period and source.
- F10-FR-04 - Submit a version for review.
- F10-FR-05 - Approve, reject or request additional evidence with comments.
- F10-FR-06 - Resubmit without overwriting prior versions.
- F10-FR-07 - Restrict download according to record permissions.
- F10-FR-08 - Expose evidence to linked audit tests when authorized.

Business rules

- F10-BR-01 - Files are stored outside PostgreSQL; metadata and links are stored in the database.
- F10-BR-02 - Review decisions are immutable records.
- F10-BR-03 - Approved evidence cannot be silently replaced.

Acceptance conditions

- F10-AC-01 - Rejected evidence remains visible with reviewer reason.
- F10-AC-02 - A resubmission creates a new version.
- F10-AC-03 - Unauthorized users cannot list, download or infer evidence metadata.

F11 - Audit Planning

Define the purpose, scope, team and schedule of an internal or compliance audit.

Dimension	Definition
Primary actors	Audit Lead, Organization Administrator, GRC Manager
Status workflow	Draft -> Planned -> In Progress -> Fieldwork Complete -> Report Review -> Completed -> Archived

Functional requirements

- F11-FR-01 - Create audit title, type, objective and scope.
- F11-FR-02 - Select departments, frameworks, risks and controls in scope.
- F11-FR-03 - Assign lead auditor and audit team.
- F11-FR-04 - Set planned and actual dates.
- F11-FR-05 - Create milestones and planning notes.
- F11-FR-06 - Move audit through controlled statuses.
- F11-FR-07 - Archive completed audits without deleting records.

Business rules

- F11-BR-01 - Only authorized audit managers can start or complete an audit.
- F11-BR-02 - Audit scope changes after start require a reason and history entry.
- F11-BR-03 - Auditors must be active tenant members.

Acceptance conditions

- F11-AC-01 - Audit cannot start without scope, lead auditor and at least one test or approved exception.
- F11-AC-02 - Status transitions reject invalid backward moves unless reopened by authorized user.
- F11-AC-03 - Audit detail shows all linked tests, findings and activity.

F12 - Audit Programs and Test Procedures

Break an audit into repeatable, assigned procedures that define what evidence and testing must be performed.

Dimension	Definition
Primary actors	Audit Lead, Internal Auditor
Status workflow	Draft -> Assigned -> In Progress -> Submitted for Review -> Reviewed -> Completed

Functional requirements

- F12-FR-01 - Create audit program sections.
- F12-FR-02 - Create test title, objective, steps and expected evidence.
- F12-FR-03 - Link tests to controls and requirements.
- F12-FR-04 - Assign auditor and reviewer.
- F12-FR-05 - Define sample method and sample size guidance.
- F12-FR-06 - Set due date and priority.
- F12-FR-07 - Clone prior approved procedures into a new audit.
- F12-FR-08 - Attach working-paper templates.

Business rules

- F12-BR-01 - A procedure template is distinct from its audit-specific test instance.
- F12-BR-02 - Assignments and due dates are tenant scoped.
- F12-BR-03 - Changes after work begins are recorded.

Acceptance conditions

- F12-AC-01 - Assigned auditors see tests in My Tasks.
- F12-AC-02 - Cloning creates new records and does not link mutable state to the source audit.
- F12-AC-03 - Tests can exist without a linked control only when justified.

F13 - Audit Testing and Fieldwork

Record the actual work, samples, exceptions, evidence and conclusion for each audit test.

Dimension	Definition
Primary actors	Internal Auditor, Audit Reviewer, Audit Lead
Status workflow	Not Started -> In Progress -> Submitted for Review -> Rework Required / Reviewed -> Completed

Functional requirements

- F13-FR-01 - Start assigned test.
- F13-FR-02 - Record methodology and work performed.
- F13-FR-03 - Create sample records and sample outcomes.
- F13-FR-04 - Attach or reference working papers and evidence.
- F13-FR-05 - Record exceptions and severity indication.
- F13-FR-06 - Select conclusion: effective, partially effective, ineffective, not tested or not applicable.
- F13-FR-07 - Submit for reviewer decision.
- F13-FR-08 - Return for rework or complete.

- F13-FR-09 - Generate a draft finding from an exception.

Business rules

- F13-BR-01 - Test conclusions require supporting notes.
- F13-BR-02 - Not Tested and Not Applicable require justification.
- F13-BR-03 - Reviewer cannot alter auditor work without a visible review event.

Acceptance conditions

- F13-AC-01 - Every exception can be traced to a sample or test observation.
- F13-AC-02 - Completed tests become read-only except through controlled reopen.
- F13-AC-03 - Finding creation carries source links to audit and test.

F14 - Audit Findings

Formally document a control weakness or exception and assign responsibility for resolution.

Dimension	Definition
Primary actors	Internal Auditor, Audit Lead, Finding Owner, GRC Manager
Status workflow	Draft -> Under Review -> Issued -> Remediation in Progress -> Awaiting Verification -> Closed / Reopened / Risk Accepted

Functional requirements

- F14-FR-01 - Create reference number, title and description.
- F14-FR-02 - Capture condition, criteria, cause, impact and recommendation.
- F14-FR-03 - Assign severity, department, owner and due date.
- F14-FR-04 - Link audit, test, risk, control and requirement.
- F14-FR-05 - Draft, review and formally issue finding.
- F14-FR-06 - Allow management response and risk acceptance proposal.
- F14-FR-07 - Track status, extensions, history and attachments.
- F14-FR-08 - Prevent closure until verification requirements are met.

Business rules

- F14-BR-01 - Finding reference is unique within tenant.
- F14-BR-02 - Only authorized audit roles can issue findings.
- F14-BR-03 - Risk acceptance requires reason and authorized approval.
- F14-BR-04 - Owner cannot directly mark finding Closed.

Acceptance conditions

- F14-AC-01 - Issued finding creates notification and task for owner.
- F14-AC-02 - Due date extension retains original date and approval history.
- F14-AC-03 - Closed finding has at least one successful verification or authorized risk acceptance.

F15 - Corrective Action Management

Translate a finding into owned, measurable remediation work with milestones and completion evidence.

Dimension	Definition
Primary actors	Finding Owner, Action Owner, Department Manager
Status workflow	Proposed -> Approved -> In Progress -> Submitted for Verification -> Verified -> Closed; or Rework Required

Functional requirements

- F15-FR-01 - Create one or more actions per finding.
- F15-FR-02 - Assign action owner, due date, priority and milestones.
- F15-FR-03 - Record plan, progress and status.
- F15-FR-04 - Upload remediation evidence.
- F15-FR-05 - Request and approve due date extensions.
- F15-FR-06 - Submit completed action for verification.
- F15-FR-07 - Escalate overdue actions.
- F15-FR-08 - Support partial closure when multiple actions exist.

Business rules

- F15-BR-01 - Action owner must be an active tenant member.
- F15-BR-02 - Completion is a submission state, not final closure.
- F15-BR-03 - All mandatory actions must be verified before normal finding closure.

Acceptance conditions

- F15-AC-01 - Progress and status remain consistent.
- F15-AC-02 - Overdue action appears on dashboards and creates notification.
- F15-AC-03 - Submission for verification locks core completion evidence until reviewer decision.

F16 - Independent Verification and Closure

Require a separate authorized user to evaluate remediation effectiveness before closing the action and finding.

Dimension	Definition
Primary actors	Independent Verifier, Audit Lead
Status workflow	Pending -> In Review -> Effective / Partially Effective / Ineffective -> Closed or Reopened

Functional requirements

- F16-FR-01 - Assign verifier.
- F16-FR-02 - Review remediation plan and evidence.
- F16-FR-03 - Record test performed and result.
- F16-FR-04 - Request additional evidence.
- F16-FR-05 - Mark effective, partially effective or ineffective.
- F16-FR-06 - Verify action and close eligible finding.
- F16-FR-07 - Reopen action or finding with reason.
- F16-FR-08 - Store closure justification and date.

Business rules

- F16-BR-01 - Verifier must not be the action owner by default.
- F16-BR-02 - Verification is an immutable decision record.
- F16-BR-03 - Finding closure validates all required actions and statuses.

Acceptance conditions

- F16-AC-01 - Invalid self-verification is blocked.
- F16-AC-02 - Reopening preserves prior verification history.
- F16-AC-03 - Closure appears in audit timeline and reporting.

F17 - Tasks and Assignments

Aggregate responsibilities from multiple modules into one prioritized personal work queue.

Dimension	Definition
Primary actors	All authenticated tenant users
Status workflow	Open -> In Progress -> Completed / Cancelled; overdue is derived

Functional requirements

- F17-FR-01 - List assigned risk reviews, control executions, reviews, audit tests, findings, actions and verifications.
- F17-FR-02 - Show source module, title, due date, priority and status.
- F17-FR-03 - Open the source record.
- F17-FR-04 - Filter by overdue, upcoming, module and status.
- F17-FR-05 - Show completed tasks for history.
- F17-FR-06 - Derive tasks from domain records or synchronize explicit task records consistently.

Business rules

- F17-BR-01 - The source domain record remains the authoritative status.
- F17-BR-02 - Task visibility follows source record authorization.
- F17-BR-03 - Completing a task must execute the domain workflow, not merely hide the task.

Acceptance conditions

- F17-AC-01 - My Tasks reflects new assignments promptly.
- F17-AC-02 - No duplicate task appears for the same assignment and stage.
- F17-AC-03 - Opening a task routes to an authorized source record.

F18 - Notifications, Reminders and Escalations

Provide basic in-app and selected email alerts for assignments, decisions and deadlines.

Dimension	Definition
Primary actors	All tenant users, System scheduler
Status workflow	Created -> Read; Email Pending -> Sent / Failed

Functional requirements

- F18-FR-01 - Create in-app notifications for assignments and workflow decisions.
- F18-FR-02 - Show unread count and notification list.
- F18-FR-03 - Mark one or all as read.
- F18-FR-04 - Link to the related record.
- F18-FR-05 - Poll using TanStack Query at a reasonable interval.
- F18-FR-06 - Create reminders for due-soon items.
- F18-FR-07 - Escalate overdue actions to configured managers.
- F18-FR-08 - Send selected transactional emails through SendGrid.
- F18-FR-09 - Record delivery attempt status for important emails.

Business rules

- F18-BR-01 - In-app notifications are stored in PostgreSQL.
- F18-BR-02 - WebSockets and Redis are not required in v1.
- F18-BR-03 - Email preferences must not disable mandatory security messages.
- F18-BR-04 - Notification creation must be idempotent for scheduled reminders.

Acceptance conditions

- F18-AC-01 - Unread count matches unread records.
- F18-AC-02 - Clicking a notification opens the related record.
- F18-AC-03 - Retry logic does not create duplicate user notifications.

F19 - Comments and Collaboration

Support contextual discussion on records without building a separate chat application.

Dimension	Definition
Primary actors	Authorized record participants
Status workflow	Posted -> Edited / Deleted

Functional requirements

- F19-FR-01 - Add comments to supported records.
- F19-FR-02 - Mention tenant users.
- F19-FR-03 - Attach small supporting files through the file abstraction.
- F19-FR-04 - Edit own recent comment if allowed.
- F19-FR-05 - Soft-delete with visible deletion marker.
- F19-FR-06 - Notify mentioned or assigned users.
- F19-FR-07 - Display chronological thread.

Business rules

- F19-BR-01 - Comment visibility inherits the parent record.
- F19-BR-02 - Edits and deletions are audit logged.
- F19-BR-03 - A user cannot mention a person outside the active tenant.

Acceptance conditions

- F19-AC-01 - Comments do not expose restricted parent records.
- F19-AC-02 - Mentioned user receives an in-app notification.
- F19-AC-03 - Deleted comments retain author and timestamp metadata.

F20 - Audit Trail and Activity History

Maintain immutable evidence of security-sensitive and material business actions.

Dimension	Definition
Primary actors	Organization Administrator, Auditor, Platform Administrator
Status workflow	Append only

Functional requirements

- F20-FR-01 - Record actor, tenant, action, entity, entity ID, timestamp and outcome.
- F20-FR-02 - Record safe before/after values for selected changes.
- F20-FR-03 - Record request correlation ID and IP where available.
- F20-FR-04 - Provide tenant-scoped audit log search.
- F20-FR-05 - Provide user-friendly activity timeline on major records.
- F20-FR-06 - Prevent modification through normal APIs.
- F20-FR-07 - Define retention and redaction rules for sensitive payload fields.

Business rules

- F20-BR-01 - Passwords, raw tokens, API keys and file contents must never be logged.
- F20-BR-02 - Audit log writes should not silently block core operations unless required by security policy; failures must be observable.
- F20-BR-03 - Platform and tenant logs are separately authorized.

Acceptance conditions

- F20-AC-01 - Sensitive actions create expected events.

- F20-AC-02 - Normal tenant users cannot update or delete audit logs.
- F20-AC-03 - Cross-tenant audit log access is blocked.

F21 - Reports and Analytics

Turn operational data into actionable summaries and exportable records.

Dimension	Definition
Primary actors	GRC Manager, Audit Lead, Organization Administrator, Viewer
Status workflow	Not applicable

Functional requirements

- F21-FR-01 - Risk register and heat map.
- F21-FR-02 - Risks by department, owner and level.
- F21-FR-03 - Compliance status by framework.
- F21-FR-04 - Requirements without controls.
- F21-FR-05 - Control execution and evidence timeliness.
- F21-FR-06 - Audit status and test completion.
- F21-FR-07 - Findings by severity and department.
- F21-FR-08 - Overdue corrective actions and average closure time.
- F21-FR-09 - Repeat findings.
- F21-FR-10 - CSV export and printable report view.

Business rules

- F21-BR-01 - Report definitions must match dashboard definitions.
- F21-BR-02 - Exports are tenant scoped and permission checked.
- F21-BR-03 - Large exports use pagination or background-ready design even if processed synchronously in v1.

Acceptance conditions

- F21-AC-01 - Report totals reconcile with source lists.
- F21-AC-02 - CSV files contain only authorized tenant data.
- F21-AC-03 - Date and timezone formatting follows tenant settings.

F22 - Search, Filtering and Saved Views

Make high-volume lists usable through consistent query, filter, sorting and pagination patterns.

Dimension	Definition
Primary actors	All tenant users
Status workflow	Not applicable

Functional requirements

- F22-FR-01 - Search primary text fields.
- F22-FR-02 - Filter by status, owner, department, severity and date range.
- F22-FR-03 - Sort allowed columns.
- F22-FR-04 - Paginate server-side.
- F22-FR-05 - Clear filters.
- F22-FR-06 - Preserve filters in URL query parameters.
- F22-FR-07 - Optionally save named views per user.
- F22-FR-08 - Return consistent metadata such as page, pageSize and total.

Business rules

- F22-BR-01 - Search and filter queries must be tenant scoped.
- F22-BR-02 - Only allowlisted sort fields are accepted.
- F22-BR-03 - Pagination limits must be bounded.

Acceptance conditions

- F22-AC-01 - Refreshing a page preserves URL-based filters.
- F22-AC-02 - Invalid sort keys are rejected or safely defaulted.
- F22-AC-03 - List queries perform acceptably with expected indexes.

F23 - Tenant Configuration

Allow each organization to tune business scales and defaults without altering application code.

Dimension	Definition
Primary actors	Organization Administrator, GRC Manager
Status workflow	Draft Change -> Validated -> Active

Functional requirements

- F23-FR-01 - Configure likelihood and impact labels.
- F23-FR-02 - Configure score-to-level ranges.
- F23-FR-03 - Configure risk categories and finding severities.
- F23-FR-04 - Configure control frequencies.
- F23-FR-05 - Configure due-soon and escalation days.
- F23-FR-06 - Configure timezone, locale and fiscal year.
- F23-FR-07 - Configure default evidence review and action deadlines.
- F23-FR-08 - Preview configuration changes.

Business rules

- F23-BR-01 - Historical records retain the values used at the time or reference versioned configuration.
- F23-BR-02 - Invalid overlapping score bands are rejected.
- F23-BR-03 - Configuration changes are audit logged.

Acceptance conditions

- F23-AC-01 - Risk scoring reflects active configuration.
- F23-AC-02 - Changing labels does not corrupt historical scores.
- F23-AC-03 - Timezone is applied consistently to scheduler and UI.

F24 - Platform Administration

Operate the SaaS tenant registry and platform status without conflating platform privileges with tenant roles.

Dimension	Definition
Primary actors	Platform Administrator
Status workflow	Provisioned -> Active -> Suspended -> Archived

Functional requirements

- F24-FR-01 - Create and activate organizations.
- F24-FR-02 - Suspend and archive organizations.
- F24-FR-03 - View tenant usage summaries.
- F24-FR-04 - View platform-level events and integration health.
- F24-FR-05 - Manage global system roles or defaults.

- F24-FR-06 - Restrict support access to tenant data.
- F24-FR-07 - Record all platform actions.

Business rules

- F24-BR-01 - Platform admin is not automatically a member of every tenant.
- F24-BR-02 - Support access must be explicit, temporary if implemented, and heavily audited.
- F24-BR-03 - No tenant impersonation in v1.

Acceptance conditions

- F24-AC-01 - Platform admin can manage status but cannot silently act as a tenant user.
- F24-AC-02 - Tenant status changes take effect on access checks.
- F24-AC-03 - All platform actions appear in platform audit logs.

F25 - AI-Assisted Drafting and Summarization

Use hosted inference for small, human-reviewed assistance without making AI a system of record or automatic decision maker.

Dimension	Definition
Primary actors	Authorized GRC users, Auditors, Control owners
Status workflow	Requested -> Generated -> Accepted / Edited / Discarded

Functional requirements

- F25-FR-01 - Draft a risk from a short problem statement.
- F25-FR-02 - Suggest candidate controls for a risk.
- F25-FR-03 - Draft a structured audit finding from test notes.
- F25-FR-04 - Summarize evidence descriptions or audit notes.
- F25-FR-05 - Return structured output validated against schemas.
- F25-FR-06 - Require user review before normal save APIs are called.
- F25-FR-07 - Record provider, model identifier, purpose, user and outcome.
- F25-FR-08 - Apply per-user and per-tenant usage limits.

Business rules

- F25-BR-01 - Groq API keys remain server-side.
- F25-BR-02 - AI output is advisory and may be inaccurate.
- F25-BR-03 - Sensitive data should be minimized before external transmission.
- F25-BR-04 - The provider and model are configuration, not hard-coded domain logic.
- F25-BR-05 - The previously selected Llama 3.1 8B model is deprecated by Groq for shutdown on 16 August 2026; implementation must use an active approved model through the adapter.

Acceptance conditions

- F25-AC-01 - AI cannot directly approve or close any GRC record.
- F25-AC-02 - Malformed model output is rejected and does not corrupt data.
- F25-AC-03 - Changing the configured model does not require changing feature controllers.

7. End-to-End Workflow Specifications

7.1 Organization Onboarding

1. Platform administrator creates an organization with a globally unique slug and Active or Provisioned status.
2. System creates default tenant configuration, standard roles and baseline permissions.
3. Organization administrator receives an invitation email through SendGrid.
4. Administrator accepts invitation, verifies email and establishes password.
5. Administrator creates departments, invites members and assigns tenant-scoped roles.
6. Dashboard displays guided empty states for the first risk, framework and control.

7.2 Risk-to-Control Workflow

7. Risk manager creates a draft risk and assigns owner and department.
8. System calculates inherent score from tenant risk matrix.
9. Risk owner proposes treatment and maps one or more controls.
10. Authorized reviewer approves the risk and treatment.
11. Control owner activates controls with frequency and evidence requirements.
12. Residual risk is assessed and retained as a new assessment entry.
13. Risk is monitored and periodically reassessed.

7.3 Control Execution and Evidence Review

14. Scheduler generates an execution for an active recurring control.
15. Performer receives an in-app notification and sees the item in My Tasks.
16. Performer starts execution, adds notes and creates an evidence draft.
17. Files or links are attached and the evidence is submitted.
18. Reviewer receives a notification and approves or rejects with reason.
19. If rejected, contributor resubmits a new version without overwriting history.
20. On approval, execution is completed and available for audit testing.

7.4 Audit-to-Finding Workflow

21. Audit lead creates audit, scope, team and dates.
22. Audit program and test procedures are assigned.
23. Auditors execute tests, select samples and reference evidence.
24. Exceptions are documented and tests are reviewed.
25. An authorized auditor drafts and issues a finding.
26. Finding owner receives notification and prepares corrective actions.

7.5 Corrective Action and Verified Closure

27. Finding owner proposes one or more corrective actions with owners and due dates.
28. Action owner performs work and submits completion evidence.
29. Independent verifier reviews evidence and performs verification steps.
30. Effective actions are verified; ineffective actions are returned for rework.
31. The finding closes only when all mandatory actions meet closure rules.
32. Closure and any reopening are recorded in activity and audit history.

7.6 State Transition Enforcement

State changes must be implemented as explicit domain commands, not unrestricted status updates. Each transition validates current state, permission, ownership, required fields and side effects such as notifications and audit events. Invalid transitions return a domain-specific 409 Conflict or 422 Unprocessable Entity response.

8. User Experience and Information Architecture

8.1 Application Shell

The web application should use a tenant-aware shell with organization switcher, side navigation, top search, notification bell, profile menu and responsive content area. Navigation items render only when the active membership has the necessary read permission, but backend enforcement remains authoritative.

8.2 Recommended Navigation

Navigation group	Screens
Overview	Dashboard, My Tasks, Notifications
GRC	Risks, Frameworks, Requirements, Controls, Control Executions, Evidence
Audit	Audits, Audit Programs, Tests, Findings, Corrective Actions, Verifications
Insights	Reports, Risk Heat Map, Compliance Coverage, Overdue Work
Administration	Organization, Members, Departments, Roles, Configuration, Audit Logs
Platform	Tenants, Platform Events, Integration Health - platform administrators only

8.3 Recommended Next.js Route Map

Route	Purpose
/[auth]/login	Login
/[auth]/forgot-password	Request reset
/[auth]/reset-password	Complete reset
/[auth]/accept-invitation	Invitation acceptance
/[orgSlug]/dashboard	Tenant dashboard
/[orgSlug]/tasks	My Tasks
/[orgSlug]/notifications	Notification center
/[orgSlug]/risks	Risk list
/[orgSlug]/risks/new	Create risk
/[orgSlug]/risks/[riskId]	Risk detail
/[orgSlug]/frameworks	Framework list
/[orgSlug]/frameworks/[frameworkId]	Framework and requirements
/[orgSlug]/controls	Control library
/[orgSlug]/controls/[controlId]	Control detail and mappings
/[orgSlug]/executions	Control execution list
/[orgSlug]/executions/[executionId]	Execution and evidence

Route	Purpose
/[orgSlug]/audits	Audit list
/[orgSlug]/audits/[auditId]	Audit workspace
/[orgSlug]/audits/[auditId]/tests/[testId]	Test workspace
/[orgSlug]/findings	Finding list
/[orgSlug]/findings/[findingId]	Finding and actions
/[orgSlug]/reports	Report hub
/[orgSlug]/settings/*	Tenant administration
/platform/*	Platform administration

8.4 Common UI Patterns

- List pages: server-side pagination, filter bar, column sorting, saved view option, CSV export permission and empty state.
- Detail pages: summary header, status badge, owner, due date, tabs for overview, related records, comments and activity.
- Forms: React Hook Form with Zod, inline field errors, unsaved-change warning and permission-aware actions.
- Workflow actions: explicit buttons such as Submit, Approve, Reject, Issue, Verify and Reopen instead of direct status dropdowns.
- Destructive actions: confirmation dialogue with impact explanation; archive preferred over delete.
- Loading: skeletons for route transitions and query loading; retry state for recoverable errors.

8.5 Accessibility Baseline

- Keyboard-accessible navigation, forms, menus, dialogs and data tables.
- Visible focus states and semantic labels.
- Color is not the only status indicator.
- Minimum practical contrast for text and controls.
- Error summaries and field-level messages.
- Charts include textual summaries and accessible data tables where practical.

9. Finalized Technology Stack

Layer	Selected technology	Role in RiskSphere
Frontend	Next.js with TypeScript, App Router	Tenant-aware web UI, routing, layouts and rendering.
UI styling	Tailwind CSS and shadcn/ui	Consistent, accessible components and rapid design implementation.
Forms	React Hook Form + Zod	Form state and client-side schema validation.
Server state	TanStack Query	REST fetching, caching, mutations, invalidation and notification polling.
Backend	NestJS with TypeScript	Business rules, authorization, modules, APIs and integration orchestration.
API style	REST over HTTPS with JSON	Simple, documented client-server contract.
API documentation	Swagger / OpenAPI	Interactive endpoint documentation and contract visibility.
Database	PostgreSQL	Relational system of record.
ORM	Prisma ORM	Typed data access and migrations.
Authentication	JWT access and refresh tokens	Stateless API authentication with revocable session records.
Authorization	Tenant-scoped RBAC plus resource constraints	Permission enforcement inside active organization context.
Email	Twilio SendGrid Email API	Invitations, verification, password reset and selected escalation emails.
AI	Groq-hosted inference through provider adapter	Small drafting and summarization features with model replaceability.
Repository	pnpm monorepo	Shared tooling, types and packages for web and API.
Testing	Jest, Supertest, Playwright	Unit, integration, API and end-to-end tests.

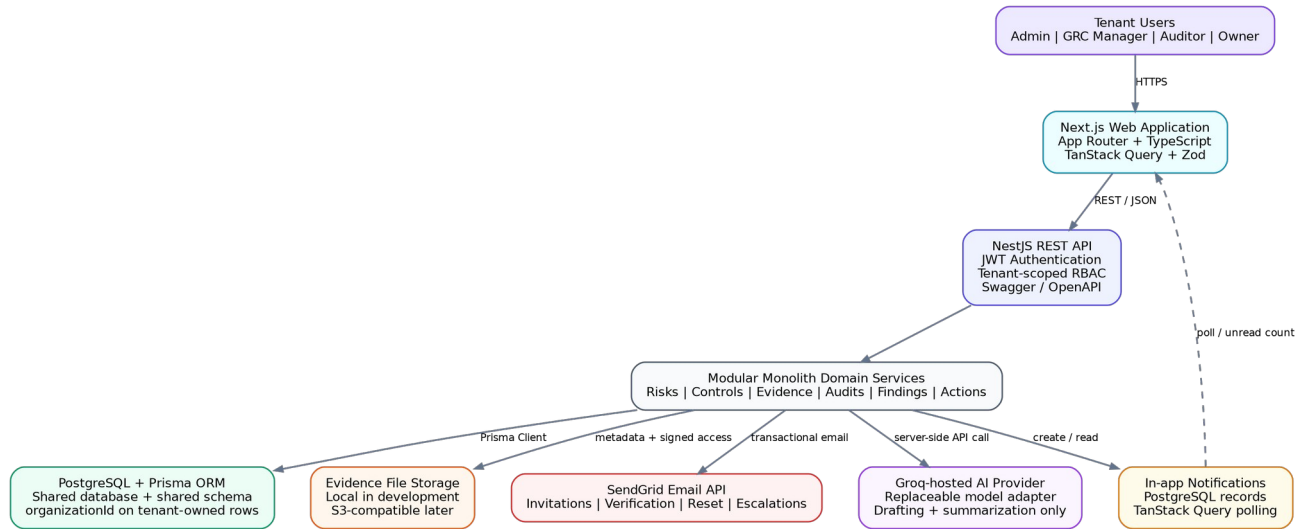
9.1 Version Baseline and Pinning Policy

Use versions that are current and generally available when implementation starts, then lock exact versions in the repository lockfile. As of the document date, Next.js documentation identifies the 16.x line as current, Prisma documentation identifies Prisma 7 as generally available, and PostgreSQL current documentation is version 18. Avoid early-access ORM releases for the baseline unless an explicit decision is made.

9.2 Why a Modular Monolith

- All modules share one deployment boundary and database transaction model.
- Complex business workflows remain easier to debug than across distributed services.
- Modules can still have strict interfaces, separate services and ownership.
- The architecture can extract a module later only when load or organizational needs justify it.

10. System Architecture



RiskSphere logical system architecture

10.1 Request Flow

33. The browser sends a REST request to NestJS with an access token and organization context derived from the tenant route or switcher.
34. Authentication guard validates token, session and account status.
35. Tenant resolver validates active membership and creates trusted request context.
36. Permission guard validates the requested action.
37. Domain service validates workflow, ownership and business rules.
38. Prisma executes organization-scoped queries in PostgreSQL.
39. Side effects create audit events, notifications and optional email or AI calls.
40. Controller returns a consistent response envelope or documented error.

10.2 Monorepo Structure

Recommended workspace:

```

risksphere/
├── apps/
│   ├── web/           # Next.js application
│   └── api/           # NestJS application
├── packages/
│   ├── api-contracts/ # Shared API types or generated client types
│   ├── validation/    # Shared safe schemas where appropriate
│   ├── ui/            # Optional shared UI components
│   ├── eslint-config/
│   └── tsconfig/
├── prisma/ or apps/api/prisma/
├── docs/
├── pnpm-workspace.yaml
└── package.json
  
```

10.3 NestJS Module Boundaries

Module	Responsibility
AuthModule	Auth

Module	Responsibility
OrganizationsModule	Organizations
MembershipsModule	Memberships
AuthorizationModule	Authorization
DepartmentsModule	Departments
RisksModule	Risks
FrameworksModule	Frameworks
RequirementsModule	Requirements
ControlsModule	Controls
ControlExecutionsModule	Control execution scheduling and workflow
EvidenceModule	Evidence
AuditsModule	Audits
AuditTestsModule	AuditTests
FindingsModule	Findings
CorrectiveActionsModule	Corrective action workflow
VerificationsModule	Verifications
TasksModule	Tasks
NotificationsModule	Notifications
CommentsModule	Comments
ReportsModule	Reports
AuditLogsModule	AuditLogs
FilesModule	Files
EmailModule	Email
AiModule	Ai
PlatformAdminModule	Platform tenant administration

10.4 Shared Packages and Contract Strategy

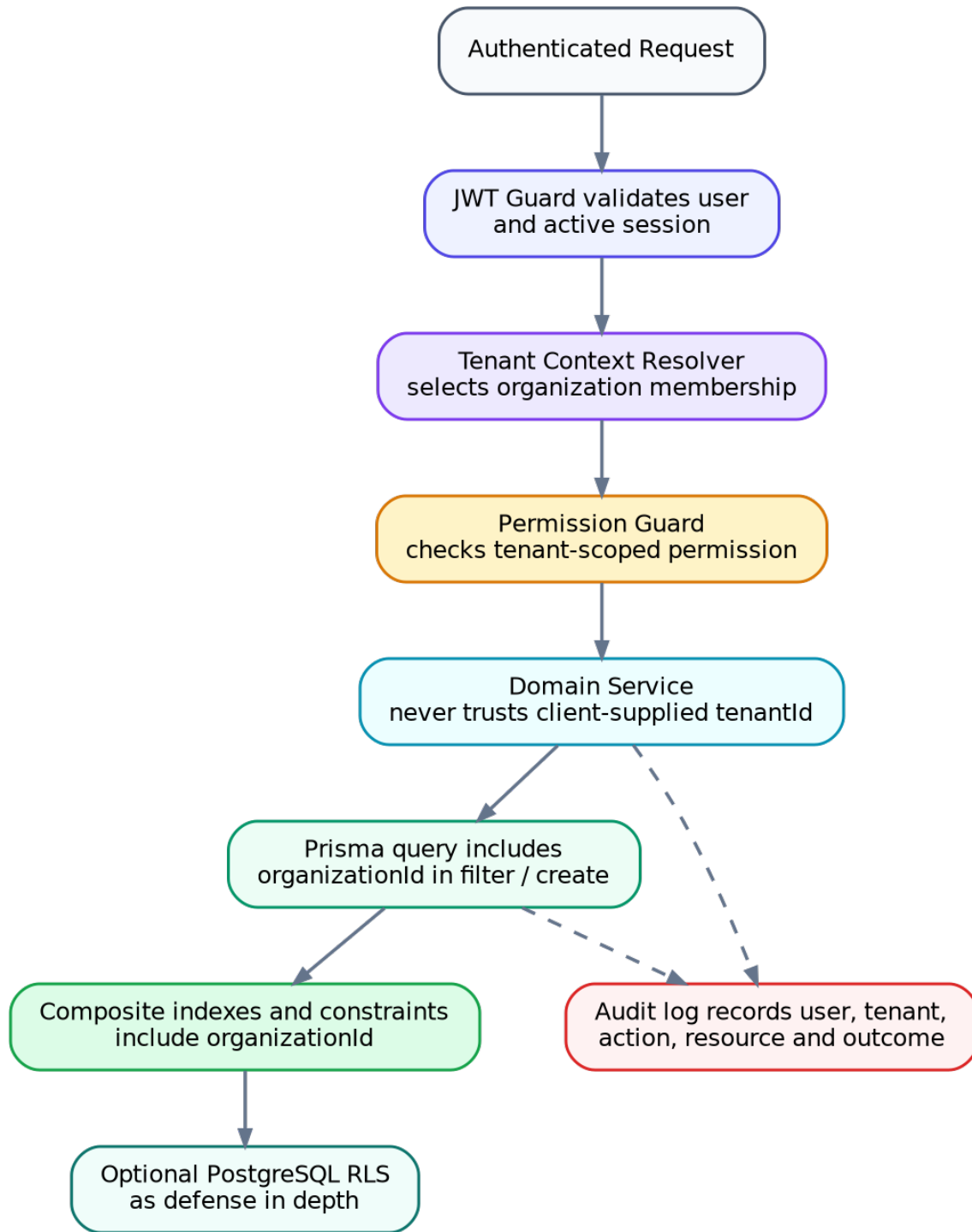
Do not import Prisma models directly into the frontend. API contracts should be explicit DTOs. Shared code may include enum constants, public response types and safe validation schemas, but backend authorization and domain validation remain authoritative. An OpenAPI-generated TypeScript client is a suitable later enhancement.

11. Multi-Tenancy Architecture

11.1 Selected Model

Decision: One PostgreSQL database, one shared schema and organizationId on every tenant-owned row.

This model is the best fit for the training scope because it supports many tenants with straightforward migrations, shared reporting patterns and lower operational complexity. It still requires rigorous query scoping and testing.



Tenant isolation enforcement chain

11.2 Tenant-Owned Data Rules

- Every tenant-owned table has a non-null organizationId foreign key.
- Create operations set organizationId from trusted request context.
- Read, update and delete operations filter by both resource ID and organizationId.
- Composite unique constraints include organizationId for tenant-local business keys.
- Join-table records also include organizationId or are validated through both parent records.

- Background jobs carry an explicit organization context.
- Cache keys, exported filenames and object-storage keys include tenant-safe namespaces.

11.3 Prisma Examples

```
model Control {
  id          String    @id @default(uuid())
  organizationId String
  code        String
  name        String
  createdAt   DateTime @default(now())
  updatedAt   DateTime @updatedAt

  organization Organization @relation(fields: [organizationId], references: [id])

  @@unique([organizationId, code])
  @@index([organizationId, updatedAt])
}

// Server-derived tenant context:
await prisma.control.findFirstOrThrow({
  where: { id: controlId, organizationId: tenant.id },
});
```

11.4 Optional Row-Level Security

PostgreSQL Row-Level Security may be introduced as defense in depth after the application-level tenancy design is stable. RLS is not a replacement for authorization. It must be tested carefully with Prisma connection behavior, transactions, database roles and session-local tenant context. The database owner and BYPASSRLS roles require special attention because they may bypass policies.

11.5 Mandatory Tenant Isolation Tests

- List endpoint does not return another tenant record.
- Detail endpoint rejects a guessed foreign resource ID.
- Update and delete reject a foreign tenant ID.
- Nested relationship creation rejects a parent from another tenant.
- Search, report and export remain tenant scoped.
- Background scheduler only generates executions for the intended tenant.
- Notification and audit log queries remain tenant scoped.

12. Authentication, Sessions and Email

12.1 JWT Strategy

Token / record	Purpose	Recommended properties
Access token	Authenticate API requests	Short-lived; signed; contains user ID, session ID and minimal claims; tenant is resolved from membership context.
Refresh token	Obtain a new access token	Longer-lived; rotated; raw value never stored; reuse detection revokes session family.
Session record	Server-side revocation and device tracking	User ID, token hash or family, created/last-used/expiry timestamps, revoked reason.
Invitation token	Join a tenant	Single use, hashed at rest, tenant and invited email bound, expiring.
Password reset token	Reset password	Single use, hashed at rest, short expiry and invalidated on use.
Email verification token	Verify email address	Single use, hashed at rest and expiring.

12.2 SendGrid Usage

SendGrid sends transactional email only. The NestJS EmailModule owns templates and provider calls. Email requests should use idempotency keys where practical and record high-level delivery status without logging secrets or sensitive message content.

Template	Trigger	Required content
Organization invitation	Admin invites member	Organization name, inviter, role summary, expiration and secure acceptance link.
Verify email	Account creation or address change	One-time verification link and expiration.
Password reset	User requests reset	One-time reset link, expiration and ignore instructions.
Password changed	Successful change/reset	Security notice and support guidance.
Critical finding assigned	High/critical finding issued	Finding reference, due date and safe link.
Overdue escalation	Action passes escalation threshold	Action, owner, age and safe link.

Current SendGrid commercial note: As of 6 August 2026, SendGrid offers a 60-day trial with up to 100 emails per day; continued sending after the trial requires a paid plan. The application should keep an EmailProvider interface so the transport can be replaced.

12.3 Authentication Security Requirements

- Use secure, HTTP-only, SameSite cookies for refresh tokens when architecture permits; avoid browser localStorage for long-lived secrets.
- Rate-limit login, password reset and verification endpoints.
- Invalidate sessions after password reset when configured.
- Do not include permissions or tenant data in tokens as the sole source of truth if they can change during token lifetime.
- Record login success, failure, lockout, reset and session revocation events.

13. Notification Design

13.1 Baseline Architecture

Basic notifications are intentionally simple: NestJS creates tenant-scoped Notification records in PostgreSQL; Next.js uses TanStack Query to fetch the unread count and list, with polling approximately every 30 to 60 seconds. No WebSocket, Socket.IO or Redis dependency is required for the initial system.

13.2 Notification Event Catalogue

Event type	Recipient	Trigger
MEMBER_INVITED	Invited user	Organization invitation created
RISK_ASSIGNED	Risk owner	Risk ownership assigned or changed
CONTROL_EXECUTION_ASSIGNED	Performer	New control execution generated
EVIDENCE_SUBMITTED	Reviewer	Evidence submitted for review
EVIDENCE_REJECTED	Contributor	Reviewer rejects evidence
AUDIT_TEST_ASSIGNED	Auditor	Test assigned
AUDIT_TEST_REWORK	Auditor	Reviewer requests rework
FINDING_ISSUED	Finding owner	Finding formally issued
ACTION_ASSIGNED	Action owner	Corrective action assigned
ACTION_DUE_SOON	Action owner	Due date enters reminder window
ACTION_OVERDUE	Owner and manager	Due date passed
VERIFICATION_REQUESTED	Verifier	Action submitted for verification
VERIFICATION_REJECTED	Action owner	Additional work required
FINDING_CLOSED	Stakeholders	Finding verified and closed
MENTION	Mentioned user	User mentioned in comment

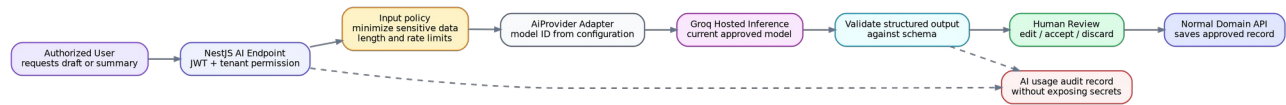
13.3 Notification Record

- id
- organizationId
- userId
- type
- title
- message
- relatedEntityType
- relatedEntityId
- actionUrl
- isRead
- readAt
- createdAt
- deduplicationKey

13.4 Scheduling Approach

A simple NestJS scheduler can run at a fixed interval to locate due-soon or overdue records. Scheduled logic must be idempotent using a deduplication key such as organizationId + event type + entity ID + reminder date. If scheduling becomes complex later, a job queue may be introduced without changing notification domain contracts.

14. AI Assistant Design



Human-in-the-loop AI assistance flow

14.1 Scope

Capability	Input	Output	Human action
Risk drafting	Short problem statement	Title, description, category suggestion, impact considerations	Review and save through Risk API
Control suggestion	Risk description and context	Candidate controls with rationale	Select, edit or discard
Finding drafting	Audit test notes and exceptions	Condition, criteria, cause, impact and recommendation draft	Auditor edits and submits
Evidence summary	Selected evidence descriptions or notes	Concise summary and key points	Reviewer uses as aid only
Audit summary	Authorized audit data subset	Executive narrative	Audit lead reviews and publishes manually

14.2 Provider and Model Decision

Groq remains the hosted inference provider because it avoids self-hosting and can be called directly from NestJS. However, model identifiers must be configuration. The previously discussed llama-3.1-8b-instant model is scheduled by Groq for shutdown on 16 August 2026, so it must not be hard-coded as the long-term baseline. At implementation time, select an active Groq model that supports the required text and structured-output behavior. The AiProvider interface prevents the feature from being coupled to a single model family.

14.3 Suggested Interface

```

export interface AiProvider {
  generateStructured<T>(input: {
    purpose: AiPurpose;
    systemPrompt: string;
    userContent: string;
    outputSchema: ZodSchema<T>;
    model?: string;
  }): Promise<{ data: T; provider: string; model: string }>;
}

```

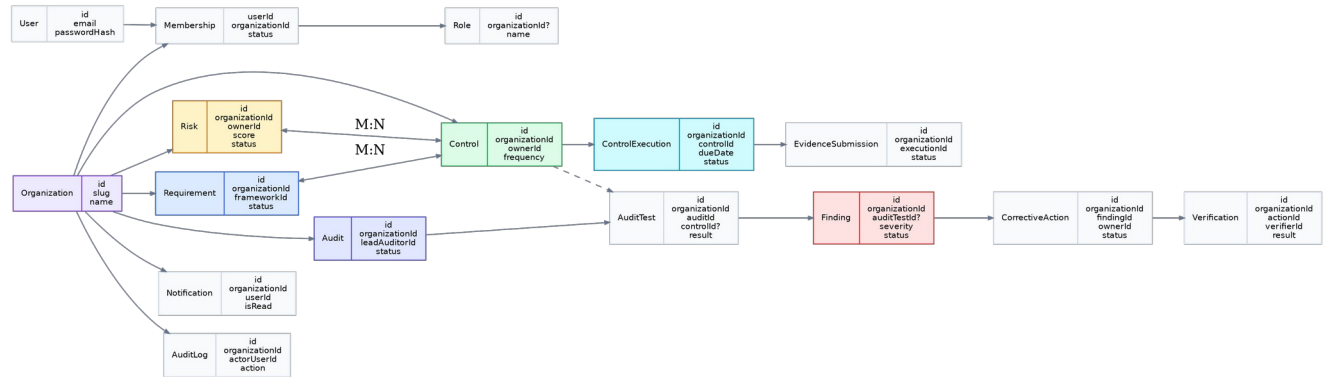
14.4 AI Safety and Privacy Rules

- Never send raw passwords, tokens, API keys or unneeded personal data.
- Minimize audit evidence and use only the authorized subset required for the request.
- Display an AI-generated label and warning that output may be inaccurate.
- Validate structured responses with Zod or backend DTO schemas.
- Do not automatically create, approve, issue, verify or close domain records.
- Apply rate limits and maximum input lengths.
- Log provider, model, user, tenant, purpose, latency and success without storing unnecessary prompt content.
- Provide a feature flag to disable AI per tenant.

14.5 Initial AI Endpoints

Method and route	Permission	Purpose
POST /v1/ai/draft-risk	ai.use + risk.create	Generate structured risk draft.
POST /v1/ai/suggest-controls	ai.use + control.manage	Suggest candidate controls.
POST /v1/ai/draft-finding	ai.use + finding.create	Generate structured finding draft.
POST /v1/ai/summarize-evidence	ai.use + evidence.review	Summarize authorized evidence text.

15. Data Model and Database Design



Simplified conceptual entity relationship model

15.1 Entity Catalogue

Entity	Purpose	Key relations
User	Global identity and account state	Membership, Session, Invitation
Organization	Tenant root	Membership, Department, all tenant-owned domain records
Membership	User access to organization	User, Organization, MembershipRole
Role	Named permission collection	Permission, MembershipRole
Permission	Atomic authorization capability	RolePermission
Department	Tenant organizational unit	Users and domain records
Invitation	Pending organization invitation	Organization, invited email, role
Session	Refresh-token session lifecycle	User
RiskCategory	Tenant risk classification	Risk
Risk	Risk register record	Owner, Department, RiskAssessment, Treatment, ControlMapping
RiskAssessment	Point-in-time inherent/residual assessment	Risk, assessor, matrix version
RiskTreatment	Treatment decision and plan	Risk, owner, actions
Framework	Compliance standard container	Requirement
Requirement	Hierarchical compliance requirement	Framework, parent requirement, ControlMapping
RequirementAssessment	Point-in-time compliance assessment	Requirement, assessor
Control	Reusable control definition	Owner, reviewer, schedules, mappings
RiskControlMapping	Many-to-many risk-control relation	Risk, Control
RequirementControlMapping	Many-to-many requirement-control relation	Requirement, Control
ControlSchedule	Frequency and generation configuration	Control
ControlExecution	One occurrence of control work	Control, performer, reviewer, EvidenceSubmission
EvidenceSubmission	Versioned evidence package	Execution, submitter, review
EvidenceItem	File, URL or text evidence	EvidenceSubmission, FileObject
EvidenceReview	Approval or rejection decision	EvidenceSubmission, reviewer

Entity	Purpose	Key relations
FileObject	Stored-file metadata	Organization, uploader, storage key
Audit	Audit plan and lifecycle	Lead, team, scope, tests
AuditTeamMember	Auditor assignment	Audit, Membership
AuditScopeItem	Risk/control/requirement/department in scope	Audit and target entity
AuditProgram	Grouped audit procedures	Audit, tests
AuditTest	Audit-specific test instance	Audit, control, requirement, assignee
AuditSample	Sample item and result	AuditTest
AuditException	Observed test exception	AuditTest or sample
WorkingPaper	Audit attachment or reference	AuditTest, FileObject
Finding	Formal deficiency	Audit, Test, Risk, Control, owner
FindingResponse	Management response or risk acceptance proposal	Finding
CorrectiveAction	Remediation work item	Finding, owner, milestones
ActionMilestone	Intermediate remediation checkpoint	CorrectiveAction
ActionEvidence	Completion evidence link	CorrectiveAction, FileObject
DueDateExtension	Controlled due-date change request	Finding or Action, approver
Verification	Independent remediation assessment	Action, verifier
TaskProjection	Optional normalized personal task view	Source record
Notification	In-app alert	User, related entity
Comment	Record-specific discussion	Author, parent entity
AuditLog	Immutable technical/business event	Actor, organization, target
ActivityEvent	User-friendly record timeline	Target entity
TenantConfiguration	Versioned tenant settings	Organization
AIInteraction	Minimal AI usage metadata	User, organization, purpose
EmailDelivery	Transactional email attempt metadata	Organization, recipient, template

15.2 Common Columns

- id: UUID primary key.
- organizationId: required on tenant-owned records.
- createdAt and updatedAt: timestamps in UTC.
- createdById and updatedById where business accountability is required.
- status: enum or constrained value with explicit transition service.
- version: optimistic concurrency field where concurrent edits are likely.
- archivedAt: soft archival for long-lived business records.

15.3 Database Constraints

- Composite unique keys such as (organizationId, code).
- Foreign keys for all required relations.
- Check constraints or service validation for date ordering and score ranges.
- Indexes beginning with organizationId for common tenant-scoped filters.
- Partial or compound indexes for active, overdue and unread records where justified by query plans.
- No cascading hard delete from major records into audit history.

15.4 Timestamp and Timezone Policy

Store timestamps in UTC. Store organization timezone as configuration. Convert due dates and scheduler boundaries using the tenant timezone. Date-only business fields should use an appropriate date type or consistently normalized UTC boundary, with behavior documented to avoid off-by-one errors.

16. REST API Design

16.1 Conventions

- Base path: /api/v1.
- JSON request and response bodies.
- Plural nouns for resources.
- Explicit action endpoints for workflow transitions, such as POST /findings/:id/issue.
- Server-side pagination with page, pageSize, total and items.
- Consistent ISO 8601 timestamps.
- Correlation ID returned in response and logs.
- Swagger documents authentication, permissions, validation and response examples.

16.2 Response Shape

```
// Success
{
  "data": { ... },
  "meta": { "requestId": "..." }
}

// Paginated success
{
  "data": [ ... ],
  "pagination": { "page": 1, "pageSize": 25, "total": 84 },
  "meta": { "requestId": "..." }
}

// Error
{
  "error": {
    "code": "EVIDENCE_INVALID_TRANSITION",
    "message": "Evidence cannot be approved from Draft status",
    "details": []
  },
  "requestId": "..."
}
```

16.3 Endpoint Inventory

Method	Route	Permission	Purpose
POST	/auth/login	Public	Authenticate user
POST	/auth/refresh	Session	Rotate tokens
POST	/auth/logout	Authenticated	Revoke session
POST	/auth/forgot-password	Public	Request reset
POST	/auth/reset-password	Token	Complete reset
GET	/organizations	Authenticated	List memberships/organizations
POST	/platform/organizations	platform.tenant.manage	Create tenant
PATCH	/platform/organizations/:id/status	platform.tenant.manage	Suspend/archive tenant
GET	/organizations/:orgId/members	member.read	List members
POST	/organizations/:orgId/invitations	member.invite	Invite member
PATCH	/memberships/:id	member.manage	Update membership
GET	/departments	department.read	List departments
POST	/departments	department.manage	Create department
PATCH	/departments/:id	department.manage	Update department
GET	/roles	role.read	List roles

Method	Route	Permission	Purpose
POST	/roles	role.manage	Create role
PUT	/roles/:id/permissions	role.manage	Replace role permissions
GET	/risks	risk.read	List risks
POST	/risks	risk.create	Create risk
GET	/risks/:id	risk.read	Risk detail
PATCH	/risks/:id	risk.update	Update risk
POST	/risks/:id/submit	risk.update	Submit for review
POST	/risks/:id/approve	risk.approve	Approve risk
POST	/risks/:id/assessments	risk.update	Create assessment
GET	/frameworks	framework.read	List frameworks
POST	/frameworks	framework.manage	Create framework
POST	/frameworks/:id/requirements	requirement.manage	Create requirement
PATCH	/requirements/:id/assessment	requirement.manage	Assess requirement
GET	/controls	control.read	List controls
POST	/controls	control.manage	Create control
GET	/controls/:id	control.read	Control detail
PATCH	/controls/:id	control.manage	Update control
POST	/controls/:id/activate	control.manage	Activate control
POST	/risks/:riskId/controls/:controlId	control.map	Map risk to control
POST	/requirements/:requirementId/controls/:controlId	control.map	Map requirement to control
DELETE	/control-mappings/:id	control.map	Deactivate mapping
GET	/control-executions	control.execute	List executions
POST	/control-executions/:id/start	control.execute	Start execution
POST	/control-executions/:id/submit-evidence	evidence.submit	Submit evidence
POST	/evidence-submissions	evidence.submit	Create evidence draft
POST	/evidence-submissions/:id/items	evidence.submit	Attach evidence item
POST	/evidence-submissions/:id/submit	evidence.submit	Submit for review
POST	/evidence-submissions/:id/approve	evidence.review	Approve evidence
POST	/evidence-submissions/:id/reject	evidence.review	Reject evidence
GET	/audits	audit.read	List audits
POST	/audits	audit.manage	Create audit
GET	/audits/:id	audit.read	Audit workspace
PATCH	/audits/:id	audit.manage	Update audit
POST	/audits/:id/start	audit.manage	Start audit
POST	/audits/:id/complete	audit.manage	Complete audit
POST	/audits/:auditId/tests	audit.manage	Create test
POST	/audit-tests/:id/start	audit.test	Start test
POST	/audit-tests/:id/samples	audit.test	Add sample
POST	/audit-tests/:id/submit	audit.test	Submit test
POST	/audit-tests/:id/review	audit.review	Review test
GET	/findings	finding.read	List findings

Method	Route	Permission	Purpose
POST	/findings	finding.create	Create finding
GET	/findings/:id	finding.read	Finding detail
POST	/findings/:id/issue	finding.issue	Issue finding
POST	/findings/:id/respond	finding.respond	Management response
POST	/findings/:id/reopen	finding.close	Reopen finding
POST	/findings/:id/actions	action.manage	Create corrective action
PATCH	/corrective-actions/:id	action.manage	Update action
POST	/corrective-actions/:id/submit	action.manage	Submit for verification
POST	/corrective-actions/:id/extensions	action.manage	Request extension
POST	/corrective-actions/:id/verifications	verification.perform	Create verification
POST	/verifications/:id/complete	verification.perform	Complete verification
POST	/findings/:id/close	finding.close	Close eligible finding
GET	/tasks	Authenticated	My Tasks
GET	/notifications	Authenticated	Notification list
PATCH	/notifications/:id/read	Authenticated	Mark read
POST	/notifications/read-all	Authenticated	Mark all read
POST	/comments	comment.create	Add comment
GET	/audit-logs	audit_log.read	Search audit logs
GET	/reports/risks	report.read	Risk report
GET	/reports/compliance	report.read	Compliance report
GET	/reports/findings	report.read	Findings report
GET	/exports/:type.csv	report.export	CSV export
POST	/files/presign-upload	file.upload	Prepare upload
GET	/files/:id/download	file.read	Authorized download
POST	/ai/draft-risk	ai.use + risk.create	AI risk draft
POST	/ai/suggest-controls	ai.use + control.manage	AI control suggestions
POST	/ai/draft-finding	ai.use + finding.create	AI finding draft
POST	/ai/summarize-evidence	ai.use + evidence.review	AI evidence summary

16.4 HTTP Status Guidance

Status	Use
200	Successful read or action with response
201	Resource created
204	Successful action with no body
400	Malformed request
401	Missing or invalid authentication
403	Authenticated but not permitted
404	Resource not found in active tenant context

Status	Use
409	State transition or uniqueness conflict
422	Business validation failure
429	Rate limit exceeded
500	Unexpected server error with request ID

17. File and Evidence Storage

17.1 Storage Abstraction

The application should define a `FileStorageProvider` interface. Development may store files on local disk, while a later environment may use S3-compatible object storage. Domain modules reference `FileObject` metadata rather than physical paths.

17.2 File Metadata

- `id`
- `organizationId`
- `originalFileName`
- `safeStoredName` or `storageKey`
- `mimeType`
- `sizeBytes`
- `checksum`
- `uploadedById`
- `createdAt`
- `scanStatus`
- `storageProvider`
- `classification` or `sensitivity`
- `deletedAt` or `retention status`

17.3 File Security

- Validate extension and MIME type; do not rely on filename.
- Generate server-controlled storage keys.
- Apply maximum file size and count limits.
- Do not expose raw local paths.
- Authorize every download against tenant and parent record.
- Use short-lived signed URLs only when a remote provider is introduced.
- Mark malware scanning as a production requirement even if simulated or deferred in training scope.

18. Reporting and Dashboard Calculations

18.1 Metric Definitions

Metric	Definition
Open risks	Risks not Closed or Archived.
High and critical risks	Active risks whose current residual level is High or Critical.
Control coverage	Applicable requirements with at least one active confirmed control mapping divided by applicable requirements.
On-time execution rate	Approved executions completed on or before due date divided by approved executions in period.
Evidence rejection rate	Rejected review decisions divided by submitted evidence versions.
Audit completion	Completed tests divided by planned active tests.
Open findings	Issued or remediation-stage findings not Closed or Risk Accepted.
Overdue actions	Actions not verified/closed with due date before tenant-local today.
Average closure time	Average elapsed days from finding issue to verified closure.
Repeat findings	Findings marked or matched as recurrence of a prior issue.

18.2 Risk Heat Map

The heat map displays current risk assessment counts by likelihood and impact. It must use the active tenant matrix, provide textual labels and allow drill-through to filtered risks. Historical heat maps may be a later enhancement.

18.3 Export Rules

- Export requests require report.export permission.
- Export columns are allowlisted.
- All rows are tenant scoped.
- Sensitive fields are excluded by default.
- Exports include generation time, tenant name and applied filters.
- CSV injection protection is applied to cells beginning with spreadsheet formula characters.

19. Security and Privacy Requirements

19.1 Security Objectives

Objective	Controls
Confidentiality	Tenant isolation, RBAC, secure tokens, file authorization and minimized AI payloads.
Integrity	Validation, state transition services, database constraints, version history and audit logs.
Availability	Graceful errors, bounded queries, integration timeouts and retry strategy.
Accountability	Actor attribution, immutable decisions, activity history and correlation IDs.

19.2 Threats and Mitigations

Threat	Mitigation
Cross-tenant IDOR	Always query by id + organizationId; integration tests for every resource type.
Privilege escalation	Permission guards, membership status checks and server-side ownership rules.
JWT theft	Short access lifetime, secure refresh cookie, session revocation and rotation.
Credential stuffing	Rate limits, generic errors and optional logout.
SQL injection	Prisma parameterization; avoid unsafe raw SQL; validate allowlisted sort fields.
Stored XSS	Escape output, sanitize rich text if introduced, strict CSP and safe markdown rendering.
Malicious file upload	Type/size validation, safe storage keys, restricted download and future malware scanning.
CSV injection	Prefix or escape formula-leading values.
Sensitive log leakage	Redaction policy and structured logging allowlist.
AI data leakage	Authorization, minimization, feature flags and no cross-tenant retrieval.
Workflow bypass	Explicit transition endpoints and domain services.

19.3 Data Classification

Class	Examples	Handling
Public	Product help and generic framework names	Normal application controls.
Internal	General risk and control metadata	Tenant authorization and audit logging.
Confidential	Evidence, findings, remediation details	Restricted permissions, secure files, minimized exports.

Class	Examples	Handling
Secret	Passwords, token hashes, API keys	Never returned, emailed, logged or sent to AI; encrypted secret management outside code.

19.4 Audit Logging Events

- Login success/failure and session revocation
- Invitation creation/acceptance
- Role or permission changes
- Tenant suspension
- Risk approval and acceptance
- Control activation/retirement
- Evidence submission and review
- Audit start/completion
- Finding issue/extension/closure/reopen
- Corrective action submission
- Verification result
- Export generation
- File download for restricted evidence
- AI request outcome and model identifier

20. Non-Functional Requirements

ID	Category	Requirement
NFR-01	Performance	Typical list and detail API responses should target sub-second server time under development-scale data, excluding external integrations.
NFR-02	Pagination	All potentially unbounded lists use server-side pagination with a maximum page size.
NFR-03	Reliability	Core mutations use database transactions when multiple records must change atomically.
NFR-04	Idempotency	Schedulers, reminders, invitation resend and selected workflow actions avoid duplicate side effects.
NFR-05	Security	OWASP-style controls, tenant isolation tests and least-privilege authorization are mandatory.
NFR-06	Accessibility	Keyboard operation, semantic labels and non-color status indicators are baseline.
NFR-07	Maintainability	Feature modules have clear controllers, services, repositories/data access and tests.
NFR-08	Observability	Structured logs, request IDs, error reporting and integration health status are available.
NFR-09	Documentation	Public REST endpoints are documented in Swagger and key architecture decisions in repository docs.
NFR-10	Data integrity	Foreign keys, unique constraints and workflow validation prevent inconsistent records.
NFR-11	Browser support	Current evergreen Chrome, Edge, Firefox and Safari.
NFR-12	Localization readiness	Store UTC timestamps and tenant timezone; English-only UI is acceptable for v1.
NFR-13	Backup readiness	Schema and file metadata design supports later backup and restore, though operations are outside scope.
NFR-14	Integration resilience	SendGrid and Groq calls have timeout, error mapping and graceful user feedback.
NFR-15	Privacy	Collect only needed user profile and activity data and define retention behavior.

20.1 Performance Indexing Priorities

- (organizationId, status, updatedAt) on major lists.
- (organizationId, ownerId, status) for personal queues.
- (organizationId, dueDate, status) for overdue and reminders.
- (organizationId, isRead, createdAt) for notifications.
- (organizationId, code) unique indexes for business identifiers.
- Full-text search may be added later; begin with indexed exact/ILIKE fields appropriate to data volume.

21. Validation and Error Handling

21.1 Validation Layers

Layer	Responsibility
Next.js / Zod	Immediate user feedback and form parsing; not authoritative for security.
NestJS DTO validation	Request shape, types, lengths and allowed values.
Domain services	State transitions, ownership, same-tenant relations and business policy.
Prisma / PostgreSQL	Foreign keys, uniqueness, non-null constraints and transaction integrity.

21.2 Common Error Codes

Code	Meaning
TENANT_CONTEXT_REQUIRED	No active tenant membership
RESOURCE_NOT_FOUND	Resource not found in active tenant
PERMISSION_DENIED	Missing permission
INVALID_STATE_TRANSITION	Requested workflow action is not valid
DUPLICATE_BUSINESS_CODE	Tenant-local code already exists
CROSS_TENANT_RELATION	Related resource belongs to another tenant
EVIDENCE_REVIEW_REQUIRED	Execution cannot complete without approved evidence
VERIFICATION_CONFLICT	Verifier is not independent
FINDING_NOT_CLOSABLE	Mandatory actions or verification incomplete
AI_OUTPUT_INVALID	Model output failed validation
INTEGRATION_UNAVAILABLE	External email or AI service unavailable

22. Testing Strategy

22.1 Test Pyramid

Test type	Tools	Focus
Unit	Jest	Scoring, transitions, permissions, serializers and pure domain logic.
Service integration	Jest + test PostgreSQL	Prisma queries, transactions, constraints and tenant scoping.
API integration	Supertest	Authentication, authorization, validation, status codes and Swagger-aligned contracts.
Frontend component	Testing Library	Forms, permissions, state and accessibility.
End-to-end	Playwright	Critical user workflows across Next.js and NestJS.
Security regression	Automated tenant matrix tests	Cross-tenant list/detail/mutation/export attempts.

22.2 Critical E2E Scenarios

- Create two tenants and prove isolation across risks, controls, evidence and findings.
- Invite user, accept invitation, log in, refresh token and log out.
- Create risk, assess, map control and approve.
- Generate control execution, submit evidence, reject and resubmit, then approve.
- Plan audit, execute test, create and issue finding.
- Create corrective action, submit evidence, verify independently and close finding.
- Attempt self-verification and confirm rejection.
- Receive and read expected notifications.
- Generate tenant-scoped CSV export.
- Use AI draft, edit it and save through normal API; confirm AI cannot auto-save.

22.3 Test Data Strategy

Seed deterministic tenants such as Acme and TripVlog Demo, with users for each persona, sample departments, risk matrices, controls and a complete closed finding. Avoid random identifiers in tests when stable fixtures improve assertion quality. Database reset scripts must never target a non-test database.

23. Development and Delivery Roadmap

The roadmap is sequenced by dependency and vertical value. Each phase should end with working UI, APIs, migrations and tests rather than backend-only completion.

Phase	Deliverables
Phase 0 - Foundation	Monorepo, linting, formatting, environment validation, shared config, PostgreSQL connection, Prisma migration workflow, Swagger, error envelope, request IDs.
Phase 1 - Identity and Tenancy	Organizations, global users, memberships, invitations, JWT sessions, SendGrid emails, departments, role and permission guards, tenant isolation tests.
Phase 2 - Risk Management	Tenant configuration, categories, risk CRUD, scoring, assessments, treatments, approvals, heat map and dashboard cards.
Phase 3 - Compliance and Controls	Frameworks, hierarchical requirements, applicability, control library, control lifecycle and mappings.
Phase 4 - Control Operations	Schedules, execution generation, My Tasks, evidence drafts, files, review, rejection/resubmission, notifications.
Phase 5 - Audit Management	Audit plans, scope, teams, programs, tests, samples, exceptions, working papers and review.
Phase 6 - Findings and Remediation	Finding issue, responses, corrective actions, due-date extensions, independent verification, closure and reopening.
Phase 7 - Insights and Governance	Reports, exports, full activity timelines, audit log explorer, advanced dashboard and search consistency.
Phase 8 - AI Assistance and Hardening	Groq provider adapter, AI drafting features, usage limits, privacy controls, performance tuning, security review and final E2E acceptance.

23.1 Definition of Done for Every Feature

- Database migration and seed updates are committed.
- NestJS DTOs, services, authorization and Swagger documentation are complete.
- Next.js list/detail/form screens and error states are complete.
- Tenant-scoped tests cover list, detail and mutation.
- Workflow side effects create expected notifications and audit events.
- Accessibility and responsive behavior are reviewed.
- No secrets or provider keys are committed.

23.2 Suggested Milestones

Milestone	Demonstrable outcome
M1	Two tenants can authenticate and manage isolated users and departments.
M2	Tenant can create and approve risks with configurable scoring.
M3	Requirements and controls are mapped with coverage reporting.
M4	Recurring execution and evidence approval work end to end.
M5	Audit fieldwork creates an issued finding.
M6	Corrective action is independently verified and finding closes.

Milestone	Demonstrable outcome
M7	Dashboards, exports, audit logs and AI assistance complete the product demo.

24. Acceptance Criteria for Product Release

24.1 Functional Release Gate

- All mandatory modules from F01 through F25 have implemented baseline requirements or documented approved exclusions.
- The complete lifecycle can be performed through the UI without manual database edits.
- At least two demo tenants prove shared-schema isolation.
- Role-based actions are denied and allowed correctly for representative personas.
- Evidence rejection and resubmission history is retained.
- Findings cannot close without satisfying independent verification rules.
- Dashboards and reports reconcile with source records.
- SendGrid invitation and password reset flows work within the configured environment.
- Groq AI features return validated drafts and never save automatically.

24.2 Technical Release Gate

- Database migrations can build a clean environment from zero.
- Swagger documents every public endpoint.
- Critical API and E2E tests pass.
- No known cross-tenant access defect remains.
- Environment variables are validated at startup.
- Secrets are excluded from repository and logs.
- External integration failures produce safe, actionable errors.
- PDF/CSV or printable exports contain only tenant-authorized data.

24.3 Demonstration Script

41. Log in as TripVlog organization administrator and show tenant dashboard.
42. Invite a Backend Engineer and Internal Auditor.
43. Create the risk "Unreliable HLS media delivery".
44. Map controls for HLS validation, signed URL duration and cross-platform playback testing.
45. Generate a weekly control execution and submit monitoring evidence.
46. Reject incomplete Android evidence, resubmit and approve.
47. Create a Streaming Reliability Audit and execute a test.
48. Issue a High finding for inconsistent feed stream URLs.
49. Assign corrective actions to Backend and DevOps.
50. Submit fix evidence, verify as Internal Auditor and close finding.
51. Show complete activity history, notification trail and report changes.
52. Use AI to draft a related risk or finding and demonstrate mandatory human review.

25. TripVlog Demonstration Case Study

25.1 Risk Record

Field	Example
Title	Unreliable reel streaming and inconsistent HLS delivery
Category	Technology / Service Availability
Owner	Backend Engineering Manager
Department	Backend Engineering
Likelihood	4 - Likely
Impact	5 - Critical
Inherent score	20 - Critical
Treatment	Mitigate
Business impact	Playback failure, buffering, lower retention, support incidents and negative store reviews.

25.2 Controls

- All uploaded videos are converted into validated adaptive HLS renditions before distribution.
- Feed APIs return only finalized media-distribution records and approved HLS URLs.
- Signed URLs remain valid for the expected playback and preload duration.
- CDN manifest and segment failure rates are reviewed weekly.
- Representative iOS and Android playback tests are completed before release.

25.3 Evidence

- HLS manifest validation output
- CDN error-rate report
- Signed URL configuration evidence
- iOS and Android playback test results
- Sample feed API responses
- Monitoring screenshots and incident notes

25.4 Audit Finding

Field	Example
Finding	Feed API returns inconsistent or incomplete stream URLs
Severity	High
Condition	Selected feed records returned a non-final or non-HLS media URL.
Criteria	Only finalized HLS distribution assets should be returned to supported clients.
Impact	Playback startup failure, quality inconsistency and increased error recovery.
Root cause	Backend media mapping did not consistently select finalized distribution assets.

Field	Example
Recommendation	Enforce finalized asset validation, add automated contract tests and monitor manifest/segment failure rates.

25.5 Corrective Actions and Verification

- 53. Backend updates mapping to return only finalized HLS URLs.
- 54. Backend adds validation for incomplete distribution records.
- 55. Engineering adds automated API and manifest tests.
- 56. DevOps adds monitoring for manifest and segment failures.
- 57. Independent auditor samples production responses on iOS and Android.
- 58. Finding closes only after tests and monitoring demonstrate effective remediation.

26. Risks, Dependencies and Architecture Decisions

26.1 Project Risks

Risk	Impact	Mitigation
Scope expansion	Too many GRC modules may delay completion	Use phased MVP and postpone vendor risk, policy and incidents.
Tenant isolation defect	Data exposure across organizations	Central tenant context, query patterns, tests and optional RLS.
Workflow complexity	Invalid or inconsistent status changes	Explicit transition services and acceptance tests.
File security	Unsafe uploads or unauthorized downloads	Storage abstraction, metadata validation and authorization.
Email trial expiration	SendGrid stops after 60-day trial	EmailProvider abstraction and development-safe fallback.
AI model deprecation	Hard-coded model becomes unavailable	Provider adapter and model ID configuration; monitor provider notices.
Reporting performance	Large aggregate queries become slow	Indexes, bounded filters and optimize after measuring.
Role explosion	Too many hard-coded roles	Permission-based authorization with a manageable seeded role set.

26.2 Architecture Decision Records

ADR	Decision	Reason
ADR-001	Next.js web + NestJS REST API	Separate frontend and backend responsibilities while sharing TypeScript ecosystem.
ADR-002	PostgreSQL + Prisma	Relational integrity, typed queries and migrations.
ADR-003	Shared database and shared schema	Best balance of complexity and realism for the project.
ADR-004	Tenant-scoped RBAC	Permissions derive from active organization membership.
ADR-005	Modular monolith	Avoid premature microservices and infrastructure.
ADR-006	Basic notification polling	Avoid WebSockets and Redis for non-real-time GRC alerts.
ADR-007	SendGrid provider abstraction	Transactional email without coupling domain logic to transport.
ADR-008	Groq AI provider adapter	Hosted inference with replaceable active model.
ADR-009	Human-in-the-loop AI	AI never makes authoritative GRC decisions.
ADR-010	Archive over hard delete	Preserve traceability and audit history.

27. Future Enhancements

Enhancement	Description
Policy Management	Policy drafting, approval, versioning and employee acknowledgment.
Vendor Risk	Third-party inventory, questionnaires, assessments and remediation.
Incident Management	Security or operational incident workflow and control linkage.
Business Continuity	Business impact analysis, plans and exercise tracking.
Enterprise SSO and MFA	SAML/OIDC, enforced MFA and identity-provider lifecycle.
Real-time Notifications	WebSockets or push where immediate delivery adds value.
Background Job Queue	BullMQ/Redis for high-volume email, exports and scheduling.
Advanced RAG	Tenant-filtered retrieval over authorized documents with citations.
Custom Workflow Builder	Configurable states and approvals after core workflows stabilize.
Custom Report Builder	User-defined dimensions, metrics and scheduled reports.
Hybrid Tenancy	Dedicated database for selected enterprise tenants.
External Integrations	Jira, Slack, Microsoft 365, ServiceNow and identity systems.

Appendix A - Status and Enum Catalogue

Enum	Values
OrganizationStatus	PROVISIONED, ACTIVE, SUSPENDED, ARCHIVED
MembershipStatus	INVITED, ACTIVE, SUSPENDED, DEACTIVATED
RiskStatus	DRAFT, UNDER_REVIEW, APPROVED, TREATMENT_IN_PROGRESS, MONITORED, CLOSED, ARCHIVED
RiskTreatmentType	ACCEPT, AVOID, MITIGATE, TRANSFER
ComplianceStatus	NOT_ASSESSED, PARTIALLY_COMPLIANT, COMPLIANT, NON_COMPLIANT, NOT_APPLICABLE
ControlType	PREVENTIVE, DETECTIVE, CORRECTIVE
ControlNature	MANUAL, AUTOMATED, HYBRID
ControlStatus	DRAFT, UNDER_REVIEW, ACTIVE, RETIRED
ControlFrequency	DAILY, WEEKLY, MONTHLY, QUARTERLY, SEMIANNUAL, ANNUAL, EVENT_DRIVEN
ExecutionStatus	SCHEDULED, IN_PROGRESS, EVIDENCE_SUBMITTED, UNDER_REVIEW, REJECTED, APPROVED, CANCELLED
EvidenceStatus	DRAFT, SUBMITTED, UNDER_REVIEW, APPROVED, REJECTED
AuditStatus	DRAFT, PLANNED, IN_PROGRESS, FIELDWORK_COMPLETE, REPORT_REVIEW, COMPLETED, ARCHIVED
AuditTestStatus	NOT_STARTED, IN_PROGRESS, SUBMITTED_FOR_REVIEW, REWORK_REQUIRED, REVIEWED, COMPLETED
AuditTestResult	EFFECTIVE, PARTIALLY_EFFECTIVE, INEFFECTIVE, NOT_TESTED, NOT_APPLICABLE
FindingSeverity	LOW, MEDIUM, HIGH, CRITICAL
FindingStatus	DRAFT, UNDER_REVIEW, ISSUED, REMEDIATION_IN_PROGRESS, AWAITING_VERIFICATION, CLOSED, REOPENED, RISK_ACCEPTED
ActionStatus	PROPOSED, APPROVED, IN_PROGRESS, SUBMITTED_FOR_VERIFICATION, REWORK_REQUIRED, VERIFIED, CLOSED
VerificationResult	EFFECTIVE, PARTIALLY_EFFECTIVE, INEFFECTIVE, ADDITIONAL_EVIDENCE_REQUIRED
NotificationStatus	UNREAD, READ

Appendix B - Recommended Seed Roles

Role	Baseline scope
Organization Administrator	Full tenant configuration and membership management; no automatic audit-verification authority.
GRC Manager	Broad risk, compliance, control, dashboard and report permissions.
Risk Manager	Risk configuration, creation, assignment and review.
Compliance Manager	Framework, requirement and control mapping management.
Control Owner	Control definition and execution oversight.
Evidence Contributor	Assigned executions and evidence submission.
Evidence Reviewer	Evidence review and decision.
Audit Lead	Audit planning, assignment, review, finding issue and closure.
Internal Auditor	Assigned test execution and finding drafting.
Finding Owner	Finding response and corrective action planning.
Independent Verifier	Verification and closure recommendation.
Viewer	Read-only access to permitted modules.

Appendix C - Source Notes and Current External Facts

The product design is primarily a project specification. The following official sources were used to validate time-sensitive technical facts as of 6 August 2026. Provider plans, model availability and framework versions can change; implementation must verify them again when development begins.

Source	Fact used	Location
Next.js documentation	App Router and TypeScript documentation; current documentation showed the Next.js 16.x line.	nextjs.org/docs
NestJS documentation	TypeScript framework and Swagger/OpenAPI module.	docs.nestjs.com
Prisma documentation	PostgreSQL support; Prisma 7 identified as the current generally available ORM release.	prisma.io/docs
PostgreSQL 18 documentation	Row Security Policies and current database documentation.	postgresql.org/docs/current
Twilio SendGrid pricing and Node.js quickstart	60-day trial and up to 100 emails per day; paid plan required after trial.	twilio.com/en-us/products/email-api/pricing
Groq model deprecation documentation	llama-3.1-8b-instant and llama-3.3-70b-versatile scheduled to shut down on 16 August 2026 for free/developer usage.	console.groq.com/docs/deprecations
Groq rate limits and model documentation	Current model limits, model capabilities and hosted API behavior.	console.groq.com/docs

Appendix D - Final Stack Decision

Final baseline: Next.js + TypeScript frontend; NestJS + TypeScript REST backend; PostgreSQL + Prisma; JWT authentication; tenant-scoped RBAC; Zod; TanStack Query; Swagger; pnpm monorepo; shared database/shared schema; SendGrid transactional email; PostgreSQL-backed basic notifications; Groq-hosted, provider-abstracted AI assistance.

End of document.